LES DOSSIERS TECHNIQUES

MEHARI–STANDARD 2022

Guide de l'utilisateur

Août 2022

Edition 2

CLUSIF

L’article L. 122-5 de la propriété intellectuelle n’autorisant pas les représentations ou reproduction intégrale, ou partielle, faite sans le consentement de l’auteur ou de l’ayant droit ou ayant cause, sauf exception stricte (« copies ou reproductions réalisées à partir d’une source licite et strictement réservées à l’usage privé du copiste et non destinées à une utilisation collective », analyses et les courtes citations dans un but d’exemple et d’illustration, etc.), toute représentation ou reproduction, par quelque procédé que ce soit du présent document sans autorisation préalable du Clusif constituerait une contrefaçon sanctionnée par les articles L. 335-2 et suivants du Code de la propriété intellectuelle.

Remerciements

Le Clusif tient à mettre ici à l'honneur les personnes qui ont rendu possible la réalisation de ce document, tout particulièrement :

Le responsable du groupe de travail :

Jean-Philippe	**JOUAS**	CLUSIF

Les contributeurs :

William	**BOURGEOIS**	KYNEO
Raphael	**DUVEAU**	NEO CONSULTING FOR YOU - NC4U
Gilles	**GOUIN**	MAX2G
Jean-Philippe	**LE LUET**	CREDIT AGRICOLE TECHNOLOGIES & SERVICES
Hélène	**LEVASSEUR**	MINISTERE DE LA SANTE ET DES SERVICES SOCIAUX DU QUEBEC
Frédéric	**MIRAULT**	SUEZ
Chantale	**PINEAULT**	CLUSIQ
Nicolas	**PLANSON**	DIGITAL SECURITY
Ferdinand	**TCHADJI**	TRUST PROVIDERS CONSULTING (TPC)

Table des matières

MEHARI–STANDARD 2022 ..... **1**

GUIDE DE L'UTILISATEUR **1**

AVANT-PROPOS **8**

GUIDE THEORIQUE MEHARI–STANDARD **9**

1. DEROULEMENT D'UN SCENARIO DE RISQUE **9**

2. MESURES DE REDUCTION DE RISQUE **11**

2.1. LES MESURES STRUCTURELLES 11
2.2. LES MESURES DISSUASIVES 11
2.3. LES MESURES PREVENTIVES 11
2.4. LES MESURES DE CONFINEMENT 11
2.5. LES MESURES PALLIATIVES 12

3. LES PARAMETRES DE L'EVALUATION DU RISQUE **14**

4. L'EVALUATION DES RISQUES **17**

GUIDE PRATIQUE POUR L'UTILISATEUR DE MEHARI–STANDARD **27**

5. VUE D'ENSEMBLE DE LA METHODE **27**

6. PRESENTATION GENERALE **28**

7. RECHERCHE ET ANALYSE DES DYSFONCTIONNEMENTS **28**

7.1. IDENTIFICATION DES DYSFONCTIONNEMENTS REDOUTES 29
7.2. ANALYSE DE LA GRAVITE DES DYSFONCTIONNEMENTS IDENTIFIES 30

8. DETERMINATION DU CADRE TECHNIQUE DE L'ANALYSE DES RISQUES **31**

8.1. PRECISION DU CADRE FONCTIONNEL DE L'ANALYSE 32
8.2. LISTE ET TYPOLOGIE DES ACTIFS PRIMAIRES 32
8.3. CRITERES DE DEFAUT, OU CRITERES DE CLASSIFICATION 32
8.4. PROCESSUS DE CLASSIFICATION 33
8.5. ÉLABORATION DES TABLEAUX D'IMPACT INTRINSEQUE 33

9. DIAGNOSTIC DE L'ETAT DES SERVICES DE SECURITE **34**

9.1. SYSTEME DE MESURE DE LA QUALITE DES SERVICES DE SECURITE 35
9.2. PROCESSUS DE DIAGNOSTIC 35
9.3. LA SYNTHESE PAR SERVICES DE SECURITE 36
9.4. FOURNITURES D'INDICATEURS RELATIFS A LA NORME ISO/IEC 27002:2022 37

10. PARAMETRAGES DE L'ANALYSE DES RISQUES **37**

10.1. DESELECTION D'ACTIVITES PRISES EN COMPTE POUR LA CLASSIFICATION 37
10.2. DESELECTION D'ACTIFS PRIMAIRES 38
10.3. DESELECTION DE TYPES D'ACTIFS SUPPORT 39
10.4. DESELECTION DES TYPES DE DOMMAGE 39
10.5. ADAPTATION DES NIVEAUX D'EXPOSITION AUX EVENEMENTS 40

10.6. DESELECTION DE TYPES D'EVENEMENTS DECLENCHEURS 41
10.7. GRILLE D'ACCEPTABILITE DES RISQUES 41
10.8. GRILLES D'ELABORATION DES STATUS-I ET STATUS-P 41

11. ÉTAT DES RISQUES 42

11.1. SELECTION DES OPTIONS DE GRAVITE DES RISQUES 42
11.2. PANORAMAS DES RISQUES 43

12. LE TRAITEMENT DES RISQUES 45

12.1. REDUCTION DES RISQUES PAR « PROJETS DE SECURITE » 45
12.2. SELECTION DE PROJETS DANS MEHARI–STANDARD 45
12.3. TRAITEMENT DES RISQUES NON REDUITS 48

13. INDICATEURS DE SUIVI ET TABLEAU DE BORD 48

ANNEXES 50

14. ANNEXE 1 : ACTIFS PRIMAIRES 50

15. ANNEXE 2 : ACTIFS SUPPORT 51

16. ANNEXE : EXPOSITION NATURELLE STANDARD

Evénements déclencheurs : types et Exposition naturelle standard

Type	*Code*	*Événement*	*Exposition naturelle standard CLUSIF*
Absence de personnel	AB.P.Per	Absence accidentelle de personnel interne ou de partenaire	3
Absence ou indisponibilité accidentelle de service	AB.S.Gen	Absence de services généraux : défaillance ou indisponibilité de services généraux ou de servitudes, énergie, climatisation, etc.	2
	AB.S.Loc	Absence de service : Impossibilité d'accès aux locaux	2
	AB.S.Mat	Absence de matériel compatible ou incompatibilité de systèmes	2
	AB.S.Ser	Absence de service : défaillance ou indisponibilité des services fournis par un prestataire externe	3
Accident grave d'environnement	AC.E.Evt	Accident grave d'environnement : Incendie, Inondation, foudroiement, tremblement de terre… ou dû à du terrorisme	2
Accident matériel	AC.M.Equ	Panne ou dysfonctionnement d'équipement	3
Action humaine (délibérée ou non) menée par voie logique ou fonctionnelle	AH.L.Blo	Attaque en blocage de comptes	2
	AH.L.Cap	Captation de données ou messages en transit	2
	AH.L.Cav	Captation visuelle de données	3
	AH.L.Cfg	Effacement volontaire ou pollution massive de configurations systèmes	2
	AH.L.Del	Effacement délibéré de supports logiques ou physiques	3
	AH.L.Fal	Falsification logique (données ou fonctions)	3
	AH.L.Fau	Création de faux (messages ou données)	3
	AH.L.Kyl	Captation de données par Keylogger logiciel	3
	AH.L.Phi	Action menée par abus de confiance (Phishing)	3
	AH.L.Sam	Saturation malveillante d'équipements informatiques ou réseaux	3
	AH.L.Tot	Destruction logique totale (fichiers et leurs sauvegardes)	2
	AH.L.Vol	Détournement logique de fichiers ou données (téléchargement ou copie)	3
Action humaine menée par voie physique	AH.P.Fal	Manipulation ou falsification matérielle d'équipement ou de media	2
	AH.P.Kyp	Captation de données par Keylogger physique	3
	AH.P.Phc	Duplication, photocopie ou consultation de media physique	3
	AH.P.Vol	Vol ou substitution physique	3
Erreur matérielle ou de comportement du personnel	ER.P.Peo	Perte ou oubli de document ou de media	3
	ER.P.Pro	Erreur de manipulation ou dans le suivi d'une procédure	3
	ER.P.Prs	Erreur de saisie ou de frappe	3
Incident dû à l'environnement	IC.E.Div	Dégâts divers dus à l'environnement (vieillissement, pollution, dégâts des eaux, surcharge électrique, etc.) ou à du vandalisme	2
Incident logique ou fonctionnel	IF.L.Lsp	Bug bloquant dans un logiciel système, middleware, applicatif ou un progiciel	2
	IF.L.Vir	Logiciel malveillant ou virus	4
Procédures adéquates non appliquées	PR.N.Nai	Procédures adéquates absentes ou méconnues	2
	PR.N.Nar	Conflit non ou mal résolu entre procédures	2
	PR.N.Nav	Procédures inappliquées volontairement	2

.....52

Avant-propos

MEHARI–Standard fait partie de l'ensemble de méthodes d'analyse de risques développées à partir du modèle de risque MÉHARI publié par le Clusif, pour la première fois en 1996.

MEHARI–Standard s'adresse plus particulièrement à des architectures moyennes comprenant un seul site et une organisation des systèmes d'information centralisée (DSI).

MEHARI–Standard est également adapté à toutes sortes d'organisations quand il est souhaité d'avoir une vision plus globale des risques et des outils de pilotage plus complets, quitte à reporter aux phases de déploiement les adaptations des décisions aux particularités et sensibilités des éléments de l'architecture.

MEHARI–Standard est également adapté aux entreprises ou organismes qui souhaitent un alignement complet des services de sécurité sur les contrôles de l'ISO 27002 :2013.

MEHARI–Standard utilise des notions générales communes à l'ensemble des versions de MEHARI et qui sont décrites en détail dans le document « MEHARI Principes fondamentaux et spécifications fonctionnelles » disponible sur le site du Clusif.

Ces notions seront rappelées dans le présent document, selon les besoins de compréhension de MEHARI–Standard.

Comment naviguer dans ce document

Des liens ont été créés un peu partout dans le document pour permettre de naviguer facilement d'un sujet à l'autre. Le tableau suivant présente les commandes pour aller et revenir d'un sujet à l'autre.

Plateforme	Commande	Effet
Windows	Ctrl-Clic	Aller vers le sujet indiqué.
	Alt-Flèche gauche	Revenir au sujet précédent
MacOS	Cmd-Clic	Aller vers le sujet indiqué.
	Alt-Flèche gauche	Revenir au sujet précédent

Guide théorique Méhari–Standard

Introduction

L'analyse de risque est un processus de plus en plus mis en œuvre par un responsable d'activité ou un dirigeant d'entreprise qui désire connaître et caractériser les risques auxquels son organisme est exposé. À la suite de ce travail essentiel, tous les risques jugés inacceptables devront être éliminés ou réduits de façon significative par des mesures appropriées.

Nous décrivons ici, sur un plan relativement théorique, un modèle sur lequel s'appuie le processus d'analyse de risque. Ce modèle, créé par Jean-Philippe Jouas et Albert Harari, a été présenté pour la première fois dans l'ouvrage paru, en 1992, aux *Editions d'Organisation* : *"Le Risque Informatique".* Il a ensuite servi de base aux développements de tous les outils de la méthode d'analyse de risque Méhari :

- Mehari–Manager BC
- Mehari–Standard

La connaissance du modèle est essentielle et fortement recommandée pour toute personne qui désire utiliser l'un ou l'autre de ces outils pour mener avec succès une analyse de risque.

La présente section est composée de 5 chapitres :

- Le chapitre « Déroulement d'un scénario de risque » décrit comment se déroule ou se concrétise un risque dans un organisme. Ceci permettra de montrer et d'expliquer les éléments qui entrent en jeu dans le cycle de vie du risque et comment ceux-ci s'enchaînent et s'influencent.

- Le chapitre « Mesures de réduction de risque » décrit les types de mesures de réduction qui visent à atténuer le risque.

- Le chapitre « Les paramètres de l'évaluation du risque » explique les paramètres d'évaluation du risque.

- Le chapitre « L'évaluation des risques » explique comment on détermine la gravité résiduelle une fois, les mesures de réduction appliquées.

- En conclusion, une synthèse est présentée.

1. Déroulement d'un scénario de risque

Un risque peut être vu comme le déroulement d'un scénario.

Les paramètres caractéristiques du risque dépendent des phases de ce scénario et nous allons donc tout d'abord décrire ces différentes phases.

Le déroulement chronologique typique d'un scénario de risque est le suivant :

A. L'organisme a des besoins de services, de données et de processus de management, besoins qui doivent cependant être précisés selon une typologie d'actifs primaires[1] tels des services de traitement de l'information externalisés, des données applicatives, ou des processus de management de la conformité aux exigences légales ou contractuelles. Ces actifs primaires se concrétisent sur des ressources appelées actifs supports[2] qui doivent être identifiées et répertoriées. On peut citer comme ressources ou actifs supports (2) l'infrastructure du système d'information, les fichiers de données et programmes, les médias supports, par exemple.

   Ces ressources ou actifs sont le sujet principal du risque : ce sont eux qui peuvent subir un dommage et le risque naît bien du fait qu'une certaine forme d'actif est susceptible de subir un certain dommage.

B. L'occurrence d'un risque nait du fait qu'un événement (3) survient, événement qui sera à l'origine des dommages subis. Ces événements peuvent être, par exemple, un accident tel que la crue d'une rivière voisine, une erreur humaine telle que la perte ou l'oubli d'un document, un acte malveillant tel qu'un acte de vandalisme.

C. L'événement va atteindre ou impliquer un actif support et va provoquer, pour celui-ci, un dommage (4). Le risque qui n'était jusqu'alors que potentiel devint un sinistre effectif. Un dommage peut ainsi être, par exemple, l'endommagement d'un élément de l'infrastructure informatique, la disparition de données, l'impossibilité de mettre en œuvre ou de faire fonctionner une ressource, etc.

D. Les conséquences du dommage sont un incident (5) qui sera décrit comme la perte de disponibilité, d'intégrité ou de confidentialité d'un actif ou d'un type d'actif donné.

E. L'incident subi par un actif va entraîner un dysfonctionnement (6) de l'entreprise, plus ou moins importants. Il s'agit donc des conséquences ressenties non plus au niveau du système d'information mais à celui de l'entreprise elle-même.

Globalement, nous présenterons le déroulement d'un scénario de risque comme l'occurrence d'un événement se traduisant par un dommage qui provoque lui-même un incident pour un actif support de l'organisme, incident entraînant un dysfonctionnement d'une activité de cet organisme.

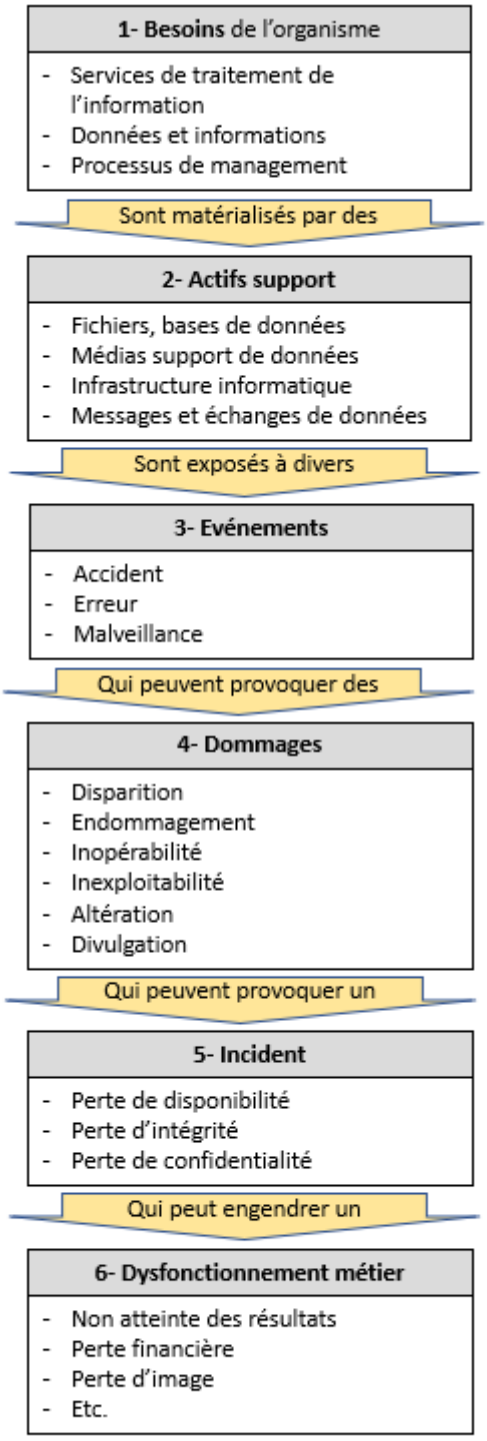


Figure 1

Nous appellerons *modèle de scénario de risque* le modèle relationnel représenté figure 1 ci-dessus.

[1] La liste des actifs primaires proposée est indiquée en annexe.
[2] La liste des types d'actifs support proposée est indiqué en annexe.

2. Mesures de réduction de risque

A chaque phase du scénario décrit ci-dessus, des mesures de sécurité peuvent avoir une influence sur son déroulement ou ses conséquences et doivent donc être positionnées dans le modèle précédent afin de pouvoir mieux caractériser le risque.

En s'appuyant sur le modèle précédent, on peut ainsi mettre en évidence cinq types de mesures de sécurité :

2.1. Les mesures structurelles

Ces mesures limitent l'exposition à certains risques, telles que des mesures de délocalisation décidées afin de situer un centre d'activité dans une zone de moindre risque, en particulier environnemental. Il peut également s'agir de mesures organisationnelles visant à éviter d'attirer l'attention d'éventuels agresseurs.

2.2. Les mesures dissuasives

Ces mesures permettent, dans le cas d'agresseurs humains, d'éviter qu'ils mettent à exécution la menace potentielle en passant à l'action. Il s'agit essentiellement d'augmenter le risque ressenti par l'agresseur ou l'acteur, s'il lui prenait envie de tenter sa chance. On vise ainsi à augmenter les deux éléments suivants :

- Le risque d'être découvert à la suite de la mise en place de moyens d'imputation de l'action à son auteur, ce qui comprend la détection de l'action et l'existence de preuves suffisamment complètes et précises pour pouvoir remonter jusqu'à l'agresseur et l'identifier sans ambiguïté ni contestation possible
- L'ampleur des sanctions encourues.

2.3. Les mesures préventives

Ces mesures permettent d'empêcher que l'événement atteigne des ressources du système d'information et provoque un incident. Elles incluent des mesures d'empêchement qui comprennent :

- L'empêchement direct d'accéder jusqu'à l'actif support ou la ressource, que ce soit par voie physique ou logique
- La détection-interception, qui arrête directement l'action avant qu'elle ne provoque un sinistre
- L'empêchement d'exploitation de l'action, en particulier par des techniques de chiffrement ou cryptage qui n'empêchent pas de saisir une information (de la voler) mais empêchent de la lire et donc de l'utiliser.

2.4. Les mesures de confinement

Ces mesures, sans empêcher les incidents, permettent tout au moins d'en limiter l'ampleur. On distingue :

- Les mesures anti-propagation qui peuvent être actives, telle la chaîne détection-réaction qui comprend une phase de détection suivie d'une phase de réaction permettant de limiter les détériorations, ou passives, telles les écrans pare-feu ou la séparation physique de sous-ensembles de ressources
- Les contrôles absolus qui, en imposant des limites à certains dommages ou certaines variations limitent les conséquences d'actions non désirées.

2.5. Les mesures palliatives

Ces mesures agissent une fois les dommages survenus, et qui permettent, d'une part d'en limiter les conséquences au niveau de l'entreprise et d'autre part de restaurer les ressources détériorées pour retrouver l'état initial. On distingue :

- Les mesures atténuant les dysfonctionnements par une reconfiguration du fonctionnement de l'organisme, que cette reconfiguration soit dynamique, par redondance, ou structurelle, par la mise en œuvre de plans de secours
- Les mesures de restauration des ressources par réparation, correction ou reconstruction.

Le modèle complété devient alors celui de la figure 2 ci-dessous.

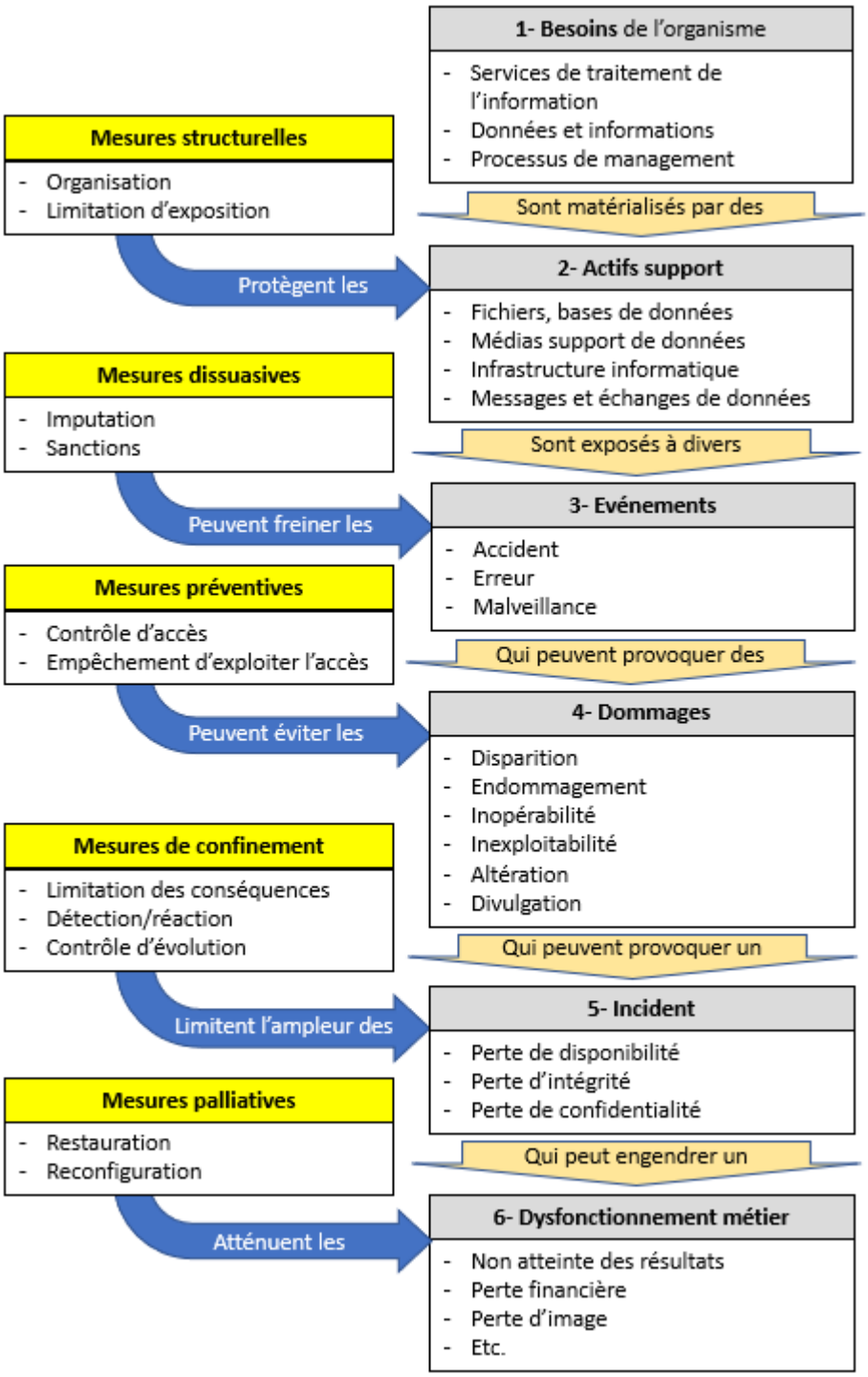


Figure 2

Modéliser et caractériser un risque consiste ainsi à décrire précisément les différentes phases du scénario de risque et leurs paramètres caractéristiques et à identifier les mesures de sécurité effectivement en place susceptibles d'avoir une influence sur ces paramètres, en s'appuyant sur la décomposition générique des mesures efficientes à chaque phase du scénario.

Eléments détaillés descriptifs des risques

Basés sur le modèle de risque décrit ci-dessus, les éléments à déterminer pour chaque scénario seront les suivants :

- L'actif primaire, correspondant à un type de service, de données, ou de processus de management dont l'organisme a besoin
- L'actif support
- L'incident subi par cet actif support
- Le dommage ayant entraîné cet incident
- L'événement ayant déclenché ce dommage

Et, pour pouvoir caractériser et évaluer chaque risque ainsi identifié :

- Les mesures de sécurité pertinentes pour ce scénario et effectivement mises en œuvre.

Le modèle de scénario de risque est ainsi très avancé. Mais le travail d'analyse ne peut être complété si on ne procède pas à une évaluation quantitative du risque.

3. Les paramètres de l'évaluation du risque

Chaque scénario de risque peut être caractérisé par la gravité de ses conséquences, son Impact et par la probabilité de l'événement qui le déclenche, que nous appelons sa Potentialité.

En l'absence de toute mesure de sécurité, nous préciserons ces deux paramètres par les concepts de « Impact intrinsèque » et de « Potentialité intrinsèque ».

La potentialité et sa métrique

La potentialité intrinsèque ou Exposition naturelle est fondamentalement la probabilité de survenance de l'événement déclencheur, en l'absence de toute mesure de sécurité.

MEHARI distingue 4 niveaux de Potentialité, notés de 1 à 4, dont les définitions générales sont données ci-après :

Niveau	Description
4 : Très probable	A ce niveau, il est raisonnable de penser que le scénario se produira très certainement et vraisemblablement à court terme. Quand le risque est survenu, personne n'est surpris.
3 : Probable	Il s'agit là des scénarios dont il est raisonnable de penser qu'ils pourraient bien se produire, à plus ou moins court terme. L'espoir que le risque ne survienne pas n'est pas insensé mais dénote un certain optimisme. La survenance du risque déçoit, mais ne surprend pas.
2 : Improbable	Il s'agit là de scénarios dont il est raisonnable de penser qu'ils ne surviendront pas. L'expérience passée montre souvent d'ailleurs qu'ils ne sont pas survenus.

	Ils demeurent néanmoins « possibles » et ne sont pas complètement invraisemblables.
1 : Très improbable	A ce niveau, l'occurrence du risque est tout à fait improbable. De tels scénarios ne sont pas strictement impossibles car il existe toujours une infime probabilité pour que cela se produise.

L'impact et sa métrique

MEHARI distingue 4 niveaux d'impact, notés de 1 à 4, dont les définitions générales sont données ci-après :

Niveau	Description
4 : Vital	Si un tel dysfonctionnement survient, l'ensemble du personnel est concerné et peut se sentir menacé dans son emploi. Pour des organismes dont la fonction ne saurait être remise en cause, en particulier les services publics, ce niveau de gravité peut remettre en question l'existence du service et le redéploiement de la fonction dans d'autres services ou ministères. Un tel niveau peut également être défini en liaison avec la gêne occasionnée dans le public : nombre de personnes touchées et durée de la perturbation. Pour les sociétés commerciales et en termes financiers, il est souvent judicieux de considérer, à ce niveau, une perte conduisant à un déficit tel que les actionnaires pourraient se désengager (avec chute du titre pour les sociétés cotées). C'est l'équivalent, dans le domaine de la santé des personnes, d'un accident ou d'une maladie « extrêmement grave », assorti d'un « diagnostic réservé » de la part des médecins. En cas de survie, les séquelles sont importantes et durables.
3 : Très Grave	Il s'agit là des dysfonctionnements très graves au niveau de l'entité, sans que son avenir soit compromis. A ce niveau de gravité, l'ensemble ou une grande partie du personnel est concerné, dans ses relations sociales et dans ses conditions de travail, mais sans risque direct pour son emploi. En termes financiers, cela peut amputer significativement le résultat de l'exercice, sans que les actionnaires se dégagent massivement. En termes d'image, on considérera souvent à ce niveau une perte d'image dommageable qu'il faudra plusieurs mois à remonter, même si l'impact financier ne peut être évalué avec précision.

	Des sinistres conduisant à une désorganisation notable de l'entreprise pendant une durée de plusieurs mois seront aussi souvent évalués à ce niveau.
2 : Important	Il s'agit là de dysfonctionnements ayant un impact notable au niveau des opérations de l'entité, de ses résultats ou de son image, mais restant globalement supportables. Seule une partie limitée du personnel serait très impliquée dans le traitement des conséquences du dysfonctionnement avec un impact significatif sur les conditions de travail.
1 : Non significatif	A ce niveau, les dommages encourus n'ont pratiquement pas d'impact sur les résultats de l'entité ni sur son image, même si certaines personnes sont fortement impliquées dans le rétablissement de la situation d'origine.

La grille d'acceptabilité des risques

La gravité du scénario ou de la situation de risque résulte à la fois de sa potentialité et de son impact.

Il ne s'agit pas, cependant, d'une opération mathématique entre ces deux valeurs mais d'un jugement et d'une décision sur le caractère acceptable ou non de la situation.

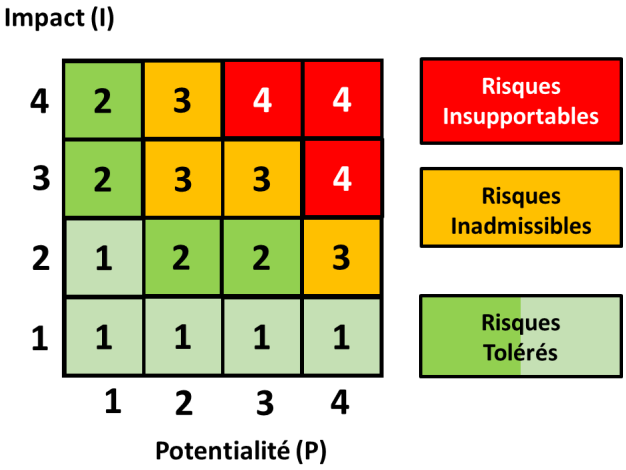
Pour prendre cette décision, MEHARI utilise une table « d'acceptabilité des risques » qui définit, en fonction de l'impact et de la potentialité estimés, si le risque est acceptable ou non.

MEHARI propose de définir trois types de risques :

- Les risques insupportables, qui devraient faire l'objet de mesures d'urgence, en dehors de tout cycle budgétaire.
- Les risques inadmissibles qui devraient être réduits ou éliminés à une échéance à déterminer, donc à prendre en compte dans une planification (plan de sécurité).
- Les risques tolérés.

Les deux premières catégories correspondent à ce que nous avons appelé les risques inacceptables.

Un exemple de telle grille est donné ci-dessous. Dans cet exemple, chaque cellule dans la partie centrale indique la gravité globale (G) évaluée en fonction de l'impact (I) et de la potentialité (P), une gravité de 4 correspond à un risque insupportable, une gravité de 3 à un risque inadmissible et les gravités inférieures à des risques tolérés.



Grille d'acceptabilité des risques

Cette grille, qui n'est pas un calcul mais le résultat d'un ensemble de décisions, est utilisée par Méhari pour évaluer la gravité des risques et il est donc important qu'elle soit validée ou amendée, au préalable, par les instances dirigeantes de l'organisme.

4. L'évaluation des risques

L'analyse de risques est une démarche qui consiste à identifier les scénarios de risques pertinents pour l'organisme, puis à évaluer chacun d'eux.

La mesure du risque repose, comme nous l'avons vu, sur deux paramètres :

- Le niveau de gravité des conséquences, que nous appelons « impact »
- Le niveau de vraisemblance ou probabilité, que nous appelons « potentialité »

Une appréciation globale et directe de ces deux paramètres s'avère généralement difficile. Il est donc préférable de recourir à une approche plus analytique en décomposant ces paramètres en plusieurs niveaux et en évaluant séparément :

- L'impact intrinsèque, hors toute mesure de sécurité
- La potentialité intrinsèque, hors toute mesure de sécurité
- L'effet des mesures de sécurité sur ces deux premiers paramètres

L'impact intrinsèque

L'impact intrinsèque est défini comme étant le niveau **maximum**[3] des conséquences possibles pour l'organisation, en l'absence de toute mesure de sécurité visant, précisément, à amoindrir ces conséquences.

Il sera défini lors de la démarche d'identification et d'évaluation des dysfonctionnements, première étape de l'analyse de risque.

[3] Suivant le principe de gestion de risque prudente qui dicte d'envisager le pire et non la moyenne, on utilise ici le niveau maximum d'impact.

La potentialité intrinsèque

La potentialité intrinsèque est définie comme étant la probabilité **maximale** de survenance du risque, donc de son événement déclencheur, en l'absence de toute mesure de sécurité visant, précisément, à amoindrir cette probabilité.

L'activité de chaque entreprise, son contexte économique, social, géographique, etc. font que chacune est plus ou moins exposée à chaque type de risque, indépendamment de toute mesure prise : une entreprise de haute technologie et leader sur son marché est plus exposée qu'une autre au risque de piratage ou d'espionnage, une entreprise localisée en bordure de rivière est plus exposée qu'une autre au risque d'inondation, une entreprise traitant des flux financiers importants est plus exposée qu'une autre à des tentatives de fraude, etc.

Il s'agit donc de s'interroger sur l'existence de facteurs pouvant favoriser l'exposition de l'entreprise au type de risque considéré et donc à l'événement qui le déclenche.

La potentialité intrinsèque d'un événement donné peut dépendre :

- De sa localisation et de son environnement, pour les risques naturels,
- De l'enjeu potentiel d'un acte volontaire, pour son auteur (vol, détournement, satisfaction intellectuelle, etc.)
- De la probabilité qu'une action volontaire vise spécifiquement l'entreprise (inversement proportionnelle au nombre de cibles potentielles : notion de ciblage)

Remarque : La potentialité intrinsèque est également appelée **« Exposition naturelle »** au risque considéré.

La potentialité intrinsèque ou exposition naturelle sera évaluée par le groupe d'analyse en se référant à l'échelle de potentialité décrite plus haut. De plus, Méhari propose une évaluation de la potentialité intrinsèque pour chaque type d'événements déclencheurs référencés par la base. Le groupe peut alors conserver ou modifier les valeurs standards indiquées par Méhari.

L'effet des mesures de sécurité sur la Potentialité et l'Impact

Prendre en compte les mesures de sécurité pour évaluer la gravité résiduelle des risques, c'est évaluer l'effet des mesures que nous avons évoquées plus haut, à savoir :

- Les mesures dissuasives,
- Les mesures préventives
- Les mesures de confinement
- Les mesures palliatives

Chacune de ces mesures pouvant être considérée comme un ***facteur de réduction de risque***.

L'effet de ces mesures est plus ou moins marqué et dépend de divers paramètres tels que la technologie employée pour les mesures techniques, les moyens humains mis en œuvre pour les mesures organisationnelles, etc.

Les mesures structurelles n'apparaissent pas volontairement ici. Celles-ci peuvent avoir une influence sur la potentialité intrinsèque ou sur l'impact intrinsèque du risque encouru. Il s'agit alors de changer « structurellement » certains aspects du contexte de l'entreprise ou de son lien avec l'environnement. Par exemple, une entreprise donnée peut être exposée à des risques environnementaux tels que des risques d'inondation, des risques sismiques, etc. Elle peut réduire le niveau de tels risques par la mise en œuvre de services de sécurité adaptés, mais elle peut aussi décider, tout simplement, de

déménager. Il s'agira alors de mesures dites structurelles car pouvant changer « structurellement » la nature ou le niveau de risque. Dans le cas d'une entreprise bancaire, celle-ci peut être exposée au risque de hold-up. Elle peut limiter le risque par des services de sécurité adaptés, mais aussi par des mesures structurelles consistant à limiter les encours disponibles.

Niveaux d'efficacité de chaque type de mesure ou niveau de chaque facteur de réduction de risque

Pour juger de leur effet, MEHARI a défini des niveaux pour chaque type d'effet, afin que les managers ou que le groupe d'analyse puissent, en se référant à ces définitions, évaluer le niveau de dissuasion, de prévention, de confinement et d'effet palliatif, de chaque mesure. Ces valeurs de référence de niveaux sont présentées dans les tableaux suivants.

Efficacité des mesures dissuasives

Niveau 0 Il n'y a pas de mesure dissuasive.	
Niveau 1 L'effet dissuasif est très faible ou nul.	L'auteur peut logiquement penser qu'il n'encourrait aucun risque personnel : il peut penser qu'il ne serait pas identifié ou qu'il aurait de très sérieux arguments pour réfuter toute imputation de l'action ou que les sanctions seraient très faibles.
Niveau 2 L'effet dissuasif est moyen.	L'auteur peut logiquement penser qu'il encourrait un risque faible et qu'en tout état de cause, les préjudices personnels qu'il aurait à subir resteraient supportables.
Niveau 3 L'effet dissuasif est important.	Un auteur rationnel devrait logiquement penser qu'il encourt un risque important : il devrait savoir qu'il serait sans doute identifié et que les préjudices qu'il aurait à subir seraient graves.
Niveau 4 L'effet dissuasif est très important.	Un auteur rationnel devrait logiquement abandonner toute idée d'action. Il devrait savoir qu'il sera presque certainement démasqué et que les sanctions encourues sont hors de proportion avec le gain espéré.

Efficacité des mesures préventives

Niveau 0 Il n'y a pas de mesure préventive.	
Niveau 1 L'effet préventif est très faible ou nul.	Toute personne proche ou appartenant à l'entreprise ou tout initié la connaissant un minimum est capable de déclencher un tel scénario, avec des moyens qu'il est facile d'acquérir. Des circonstances tout à fait courantes (maladresse, erreur, conditions défavorables non exceptionnelles) peuvent être à l'origine d'un tel scénario.

Niveau 2 L'effet préventif est moyen.	Le scénario peut être mis en œuvre par un professionnel sans autres moyens que ceux dont disposent les personnels de la profession. Des circonstances naturelles rares peuvent aboutir à ce résultat.
Niveau 3 L'effet préventif est important.	Seul un spécialiste, un professionnel doté de moyens très importants, ou une collusion entre plusieurs professionnels ayant des domaines différents peuvent aboutir. Concours de circonstances rares ou circonstances exceptionnelles exigées.
Niveau 4 L'effet préventif est très important.	Seuls quelques experts, dotés de moyens très importants, peuvent aboutir. Seuls des concours exceptionnels de circonstances exceptionnelles peuvent conduire à ce scénario.

Efficacité des mesures de confinement

Niveau 0 Il n'y a pas de mesure de confinement.	
Niveau 1 L'effet de confinement est très faible ou nul.	Soit le sinistre ne peut être limité dans ses conséquences directes, soit il ne sera détecté qu'au bout d'un délai important. Les mesures que l'on peut prendre alors n'auront qu'une influence très limitée sur le niveau des conséquences directes.
Niveau 2 L'effet de confinement est moyen.	Le sinistre peut être limité dans ses conséquences directes mais l'effet est très limité, ou le délai de détection n'est pas rapide et/ou les réactions sont tardives. Les mesures que l'on peut prendre alors ont une influence réelle sur l'impact, mais l'ampleur des conséquences directes reste importante.
Niveau 3 L'effet de confinement est important.	Les limitations absolues ont un effet important sur les conséquences. Les mesures que l'on peut prendre alors ont une influence réelle sur l'impact direct, qui est réel mais limité et circonscrit.
Niveau 4 L'effet est très important.	L'effet d'atténuation de l'impact est très important et l'impact direct très réduit et aisément supportable.

Efficacité des mesures de palliatives

Niveau 0 : Il n'y a pas de mesure palliative.	
Niveau 1 L'effet de limitation des conséquences indirectes est très faible ou nul.	Les mesures seront totalement improvisées et/ou il est raisonnable de penser que leur effet en sera très faible.
Niveau 2 L'effet de limitation des conséquences indirectes est moyen.	Les solutions de secours ou moyens palliatifs ont été prévus globalement et pour l'essentiel, mais l'organisation de détail n'a pas été faite. Il est raisonnable de penser qu'il résultera de ce manque de préparation un manque d'efficacité très net des mesures prévues. Le délai de reprise du fonctionnement normal de l'activité ne peut être connu avec précision ou ne changera pas fondamentalement le niveau de gravité du sinistre.
Niveau 3 L'effet de limitation des conséquences indirectes est important.	Les mesures ont été analysées et organisées dans le détail, puis validées. Le délai de reprise du fonctionnement normal de l'activité peut être estimé ou connu avec précision et est tel que cela réduira notablement la gravité des conséquences indirectes du scénario.
Niveau 4 L'effet de limitation des conséquences indirectes est très important.	Le fonctionnement normal de l'activité est assuré sans discontinuité notable.

Effets cumulés de plusieurs mesures

MEHARI considère que si plusieurs mesures concourent au même facteur de réduction de risque, la mesure la plus efficace donne le niveau atteint, ce qui revient à dire que plusieurs mesures de même niveau n'augmentent pas le niveau final.

L'évaluation de l'impact et de la potentialité (résiduels ou actuels) des risques

Ces deux évaluations se font à partir des évaluations d'impact intrinsèque, de potentialité intrinsèque et des facteurs de réduction de risque.

Évaluation de la potentialité résiduelle

Il s'agit, pour la potentialité, d'un jugement porté sur le niveau de potentialité en fonction des éléments du scénario de risque et qui revient à poser la question suivante :

Compte tenu de la potentialité intrinsèque (ou de l'exposition naturelle au risque), du niveau des mesures dissuasives (pour une action humaine) et du niveau des mesures préventives, à quel niveau évalue-t-on la potentialité résiduelle du risque ?

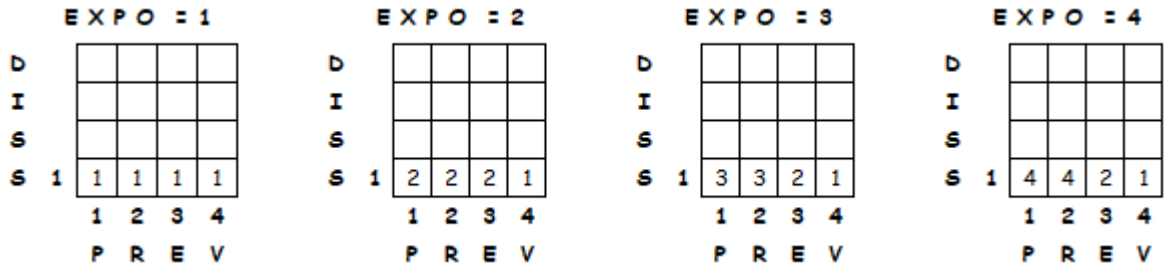
Cette évaluation est de l'ordre de la décision, mais afin de rendre les jugements correspondants reproductibles, MEHARI propose de s'appuyer sur des grilles de décision standard en fonction des éléments suivants :

- Le type de scénario (accident, erreur ou action volontaire humaine)
- Le niveau de l'exposition naturelle (EXPO)
- Le niveau d'efficacité des mesures dissuasives (DISS)
- Le niveau d'efficacité des mesures préventives (PREV)

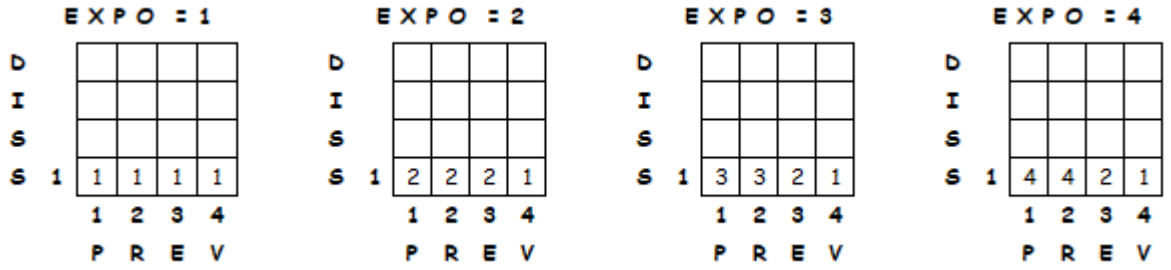
pour déterminer le niveau de potentialité résiduelle.

Voici les grilles pour déterminer la potentialité résiduelle d'un risque pour chaque type de scénario :

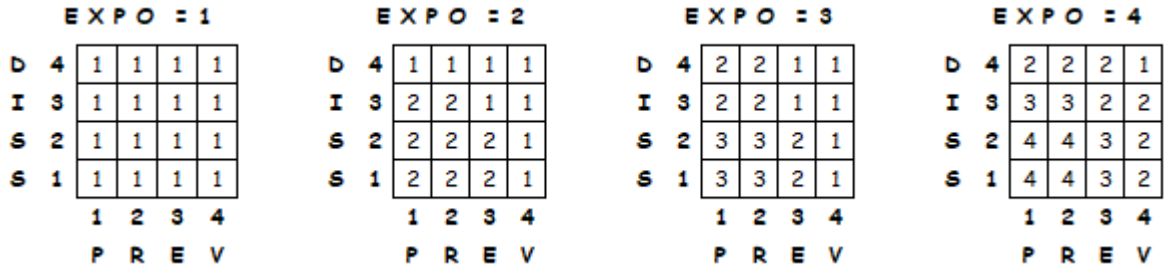
Type de scénario : Accident



Type de scénario : Erreurs



Type de scénario : Action volontaire



Voici un exemple simple pour bien comprendre comment ces grilles sont utilisées pour déterminer la potentialité résiduelle d'un acte volontaire pour laquelle l'organisation juge

- Qu'elle est exposée au niveau EXPO = 4
- Que le niveau d'efficacité de la mesure de dissuasion est DISS = 3
- Que le niveau d'efficacité de la mesure de prévention est PREV = 2

alors en se référant à la grille EXPO = 4 concernant une action volontaire, on voit que la potentialité passe de la valeur EXPO = 4 à la valeur EXPO = 3

À noter que les grilles précédentes sont modifiables. Toutefois, il est impératif d'utiliser des grilles stables dans le temps. Si les grilles changent d'une étude à l'autre, cela signifie que pour un même niveau de dissuasion, un même niveau de prévention et une potentialité résiduelle obtenue dans une étude précédente, on obtiendra une potentialité résiduelle différente dans une autre étude utilisant les grilles modifiées. Les comparaisons sont alors impossibles et les décisions prises moins crédibles. Avec des grilles stables, ces problèmes ne surviennent pas.

Évaluation de l'impact résiduel

Il s'agit, pour l'impact, d'un jugement porté sur le niveau d'impact en fonction des éléments du scénario de risque et qui revient à poser la question suivante :

Compte tenu de l'impact intrinsèque, du niveau des mesures de confinement (pour les scénarios qui peuvent l'être) et du niveau des mesures palliatives, à quel niveau évalue-t-on l'impact résiduel du risque ?

Cette évaluation est de l'ordre de la décision, mais afin de rendre les jugements correspondants reproductibles, MEHARI propose de s'appuyer sur des grilles de décision standard en fonction des éléments suivants :

- L'aspect affecté par le scénario (disponibilité, intégrité, confidentialité ou efficience)
- Le niveau d'impact intrinsèque (II)
- Le niveau d'efficacité des mesures de confinement (CONF)
- Le niveau d'efficacité des mesures palliatives (PALL)

pour déterminer le niveau d'impact résiduel.

Voici les grilles pour déterminer l'impact résiduel d'un risque pour chaque aspect :

Aspect : Disponibilité

II = 1

CONF \ PALL	1	2	3	4
C 4	1	1	1	1
O 3	1	1	1	1
N 2	1	1	1	1
F 1	1	1	1	1

II = 2

CONF \ PALL	1	2	3	4
C 4	2	2	1	1
O 3	2	2	1	1
N 2	2	2	2	1
F 1	2	2	2	1

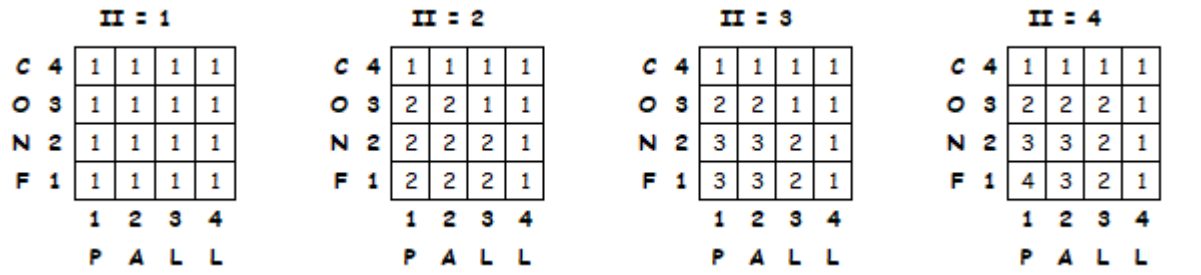
II = 3

CONF \ PALL	1	2	3	4
C 4	2	2	1	1
O 3	3	2	2	1
N 2	3	3	2	1
F 1	3	3	2	1

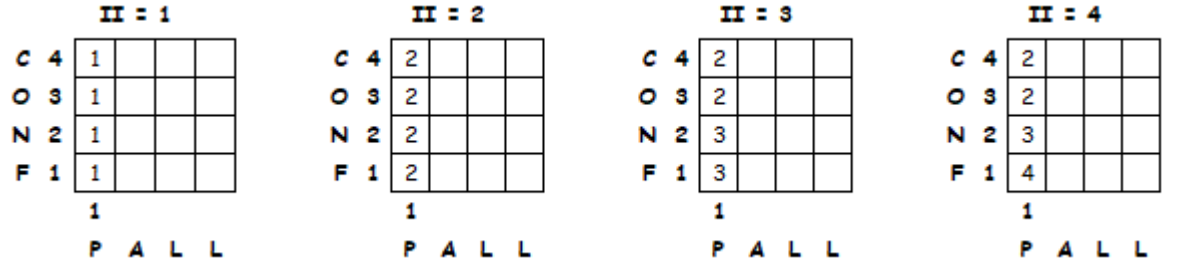
II = 4

CONF \ PALL	1	2	3	4
C 4	2	2	2	1
O 3	3	3	2	1
N 2	4	3	2	1
F 1	4	3	2	1

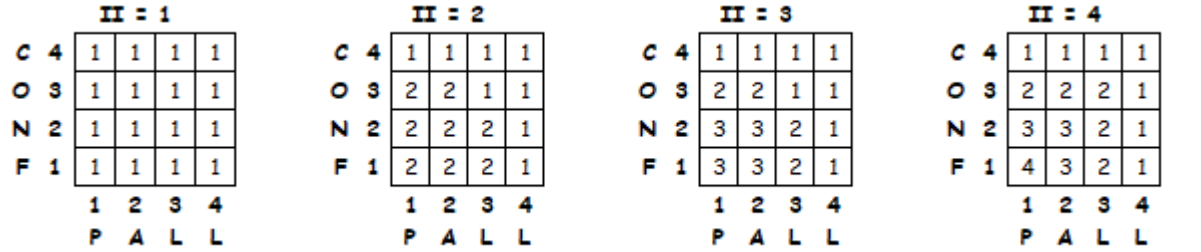
Aspect : Intégrité



Aspect : Confidentialité



Aspect : Efficience



Voici un exemple simple pour bien comprendre comment ces grilles sont utilisées pour déterminer l'impact résiduel pour un scénario touchant la disponibilité pour laquelle l'organisation juge

- Que l'impact intrinsèque est II = 3
- Que le niveau d'efficacité de la mesure de confinement est CONF = 2
- Que le niveau d'efficacité de la mesure palliative est PALL = 4

alors en se référant à la grille concernant la disponibilité II = 3, on voit que l'impact résiduel passe de la valeur II = 3 à la valeur II = 1.

À noter que les grilles précédentes sont modifiables. Toutefois, il est impératif d'utiliser des grilles stables dans le temps. Si les grilles changent d'une étude à l'autre, cela signifie que pour un même niveau de confinement, un même niveau de palliation et un impact résiduel obtenu dans une étude précédente, on obtiendra un impact résiduel différent dans une autre étude utilisant les grilles modifiées. Les comparaisons sont alors impossibles et les décisions prises moins crédibles. Avec des grilles stables, ces problèmes ne surviennent pas.

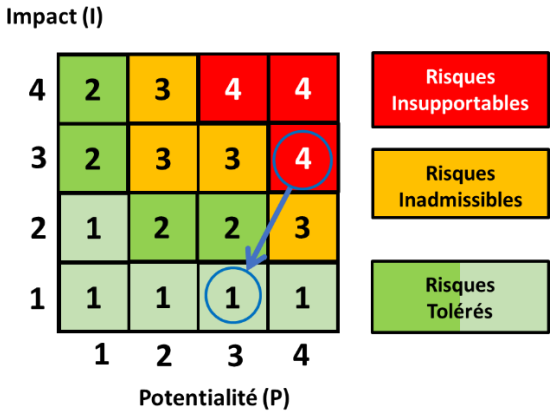
L'appréciation globale du risque résiduel

L'appréciation globale de chaque risque repose ainsi sur une double évaluation, celle de sa potentialité résiduelle et celle de son impact résiduel. C'est en fonction de ces deux paramètres que les risques seront évalués, selon les processus décrits plus haut, en fonction de la grille d'acceptabilité des risques.

Le tableau suivant résume bien la situation pour les deux exemples précédents.

	Potentialité	Impact	Gravité	Qualification du risque
Intrinsèque	4	3	4	Insupportable
Résiduel(le)	3	1	1	Tolérable

En examinant la grille d'acceptabilité des risques, on constate que le risque initialement intolérable deviendra tolérable à la suite de la mise en place des mesures de mitigation.



Conclusion

En résumé, toute organisation a des besoins opérationnels (ex : services de traitement de l'information, données et informations, processus de management) qu'elle doit protéger adéquatement pour remplir sa mission d'affaires. Ces besoins se concrétisent par des actifs supports (fichiers, bases de données, infrastructure informatique, messages et échanges de données). Ces actifs sont exposés à des événements malencontreux (accidents, erreurs, malveillance). Ces événements induisent des dommages (disparition, endommagement, inopérabilité, inexploitabilité, altération, divulgation) sur les actifs. Les dommages engendrent des incidents (perte de disponibilité, perte d'intégrité, perte de confidentialité). Ces incidents provoquent des dysfonctionnements métiers (non-atteinte des résultats, pertes financières, pertes d'image, etc.).

Pour réduire la probabilité (ou potentialité) que les événements malencontreux se produisent, les gestionnaires peuvent décider d'implanter des mesures de dissuasion et des mesures de prévention. Les grilles relatives à la potentialité (appelé STATUT-P dans Méhari) sont utilisées pour mesurer la réduction de la potentialité par les mesures. Plus ces mesures sont efficaces, plus la potentialité est réduite.

Dans l'éventualité où les événements malencontreux se produiraient malgré les mesures de dissuasion et de prévention en place, les gestionnaires peuvent aussi prévoir des mesures de confinement et des mesures palliatives. Les grilles relatives à l'impact (appelé STATUT-I dans Méhari) sont utilisées pour mesurer la réduction de l'impact par les mesures. Plus celles-ci sont efficaces, plus l'impact est réduit.

En l'absence de mesure, la gravité du risque est déterminée par la potentialité intrinsèque et l'impact intrinsèque. Les mesures qui modifient ces deux facteurs permettent donc de réduire la gravité à un niveau que les gestionnaires sont prêts à supporter.

Le processus d'analyse de risques vise donc à identifier les scénarios de risques, les actifs supports impliqués, les événements possibles, les dommages potentiels et les incidents en vue de déterminer les mesures les plus efficaces à mettre en place pour réduire la gravité des risques identifiés.

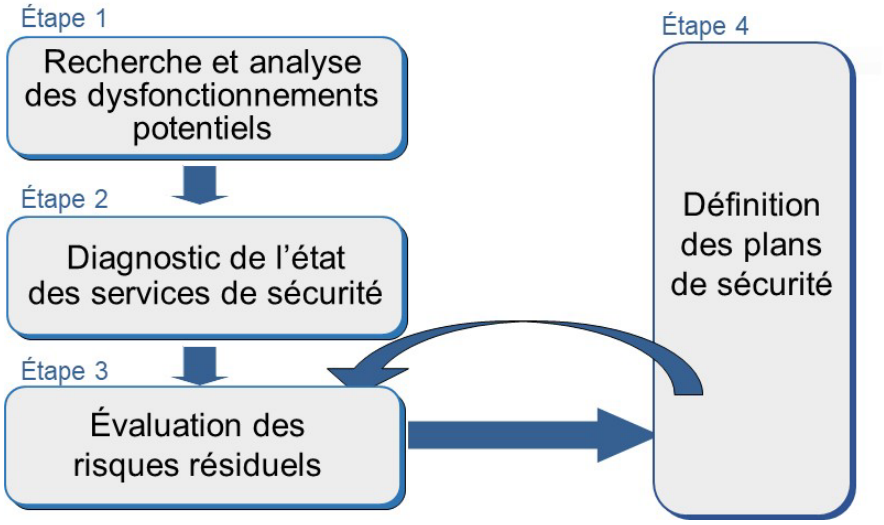
Guide pratique pour l'utilisateur de MEHARI–Standard

5. Vue d'ensemble de la méthode

MEHARI–Standard s'appuie sur une base de connaissance et consiste à :

- Procéder à une analyse des activités de l'organisme, à en déduire les dysfonctionnements qui peuvent être redoutés, puis à évaluer en quoi ces dysfonctionnements peuvent être plus ou moins graves,
- Procéder à un diagnostic de l'état des services de sécurité auprès des divers responsables techniques ou organisationnels.
- Analyser les risques résultants et sélectionner les services de sécurité à améliorer pour réduire les risques inadmissibles, avec l'aide des outils de simulation
- Décider des plans d'action retenus et les planifier

Le schéma ci-dessous résume la démarche.



MEHARI–Standard offre plusieurs types d'indicateurs et de tableau de bord :

- Une vision de synthèse des risques : nombre de scénarios de risque positionnés sur une grille I/P (Impact/Potentialité)
- Un tableau du nombre de scénarios de risque par domaine de scénario (par type d'actifs et par type de dommage – D, I, C)
- Un tableau du nombre de scénarios de risque par gravité et par type d'événement déclencheur

6. Présentation générale

MEHARI–Standard se présente sous la forme d'un classeur Excel qui comporte essentiellement les modules et éléments décrits dans le tableau ci-dessous.

Onglet	Objectif	Masquer les onglets sélectionnés ci-dessous
Intro	Description et navigation entre les onglets du fichier de la base de connaissance	
Présentation	Présentation de Méhari Standard et de la démarche de traitement des risques	
Module d'analyse des enjeux et classification des actifs:		**Tableaux de classification :** T1, T2, et Classif — Masquer ➔ ☐
T1 et T2	Tableaux de classification	
Classif	Classification des actifs	
Module du diagnostic des services de sécurité (ou d'audit)		**Questionnaires :** de 1 Org à 8 Cex et Score ISO — Masquer ➔ ☐
Domaines 1 Org à 8 Cex	Questionnaires relatifs aux domaines (1 à 8) de sécurité MEHARI	
Services	Récapitulé de la qualité des services de sécurité (avec variantes)	
Score ISO	Table de scoring ISO 27002 suite au diagnostic des services Méhari	
Module d'analyse de risque (identification, estimation et évaluation des risques)		**Analyse des risques :** Risques par actifs ou événements — Masquer ➔ ☐
Scénarios	Scénarios de risque incluant le calcul des risques	
Risk%Actif	Panorama de gravité des scénarios par type d'actif	
Risk%event	Panorama de gravité des scénarios par type d'événement	
Traitement des risques : options, plans de réduction et suivi		**Traitement des risques :** Plans_d'action, Projets, Sel_Projets — Masquer ➔ ☐
Plans_action	Présélection de Projets de réduction des risques, par domaine de risques	
Projets	Sélection directe et planification des projets	
Sel_Projets	Aide à la sélection de Projets de réduction des risques	
Tbord	Indicateurs et tableau de bord	
Eléments de paramétrage de la méthode		Grilles d'acceptabilité des risques et d'évaluation de I et P — Masquer ➔ ☐
Actifs_supports	Actifs supports objets de la menace et sujets à dommage	
Dommages	Dommages subis par l'actif support	
Expo	Événements déclencheurs des risques	
Gravité	Détermination de la Gravité du risque en fonction de la Potentialité et de l'Impact	
Grilles IP	Tables de détermination d'Impact et de Potentialité des scénarios	

Les points clés de l'utilisation de cet outil seront décrits dans les chapitres suivants.

7. Recherche et analyse des dysfonctionnements

L'objectif de la première étape de la démarche est d'identifier les dysfonctionnements potentiels significatifs des activités du domaine analysé et d'attribuer à chaque dysfonctionnement une valeur ou une échelle de valeurs[4].

Cette analyse se déroulera en deux sous-étapes :

- L'identification des dysfonctionnements redoutés.
- L'analyse de la gravité des dysfonctionnements identifiés.

A noter que cette étape essentielle de l'analyse des risques est basée sur les enjeux « métiers » et est donc hors du champ de la base de connaissance technique de MEHARI–Standard.

Par la suite, la liste des dysfonctionnements servira de base pour procéder à des analyses de risques spécifiques.

[4] Pour des informations complémentaires concernant les dysfonctionnements, on pourra consulter le guide « Méhari – Guide de l'analyse des enjeux et de la classification ».

7.1. Identification des dysfonctionnements redoutés

L'étape 1.1 consiste à rechercher les dysfonctionnements redoutés pour le domaine concerné par l'analyse. Un bon point de départ est d'identifier les activités majeures ou les principaux processus du domaine analysé, de les décrire en quelques mots et de noter en regard les résultats attendus ou les objectifs.

7.1.1 Résultats attendus

La description des dysfonctionnements doit être telle qu'il soit possible ensuite d'en évaluer la gravité.

Il est souhaitable, à ce niveau, de se concentrer sur les dysfonctionnements potentiels au niveau fonctionnel. Il s'agit donc de dysfonctionnements dans le déroulement attendu de l'activité et l'on peut éventuellement s'appuyer sur la typologie générique des dysfonctionnements indiquée dans le tableau suivant :

Type de dysfonctionnement	***Dysfonctionnement***
Défaut de ponctualité	Les tâches prévues ou les activités ne sont pas effectuées dans les délais prévus.
Non-conformité	Les tâches prévues ou les activités ne sont pas effectuées conformément à ce qui est spécifié.
Manque d'exhaustivité	Les tâches prévues ou les activités ne sont effectuées que partiellement (mais ce qui est effectué est conforme à ce qui est spécifié).
Défaut de discrétion	Des informations sont divulguées à l'occasion de l'accomplissement des tâches ou activités.

Il est souvent utile de décrire en outre les conséquences redoutées, afin de mieux pouvoir juger de leur gravité.

Ainsi, par exemple, dans l'hypothèse de la divulgation des salaires du personnel, il peut être utile de préciser les conséquences redoutées : déclenchement d'une grève, obligation de procéder à des augmentations nombreuses pour des catégories de personnel, perte de motivation du personnel, etc.

De même, si le dysfonctionnement envisagé est l'altération de la paye, il est nécessaire de préciser si les conséquences redoutées sont une fraude et la perte d'argent ou la grève du personnel ou sa démotivation ou l'obligation de gérer des rappels nombreux et compliqués.

Chaque dysfonctionnement sera décrit, au niveau fonctionnel, comme une altération du déroulement attendu de l'activité et donc par l'activité, par le type de dysfonctionnement et par ses conséquences.

Par exemple, pour la gestion de trésorerie, déjà évoquée :

Activité	Type de dysfonctionnement	Conséquences
Gestion des comptes de trésorerie	Retard dans l'approvisionnement des comptes	Incapacité à payer les fournisseurs se traduisant par un arrêt des livraisons et un arrêt de la production

7.1.2 Démarche

Ici encore, l'expérience prouve qu'au bon niveau de responsabilité, donc avec les managers, les dysfonctionnements majeurs sont très rapidement mis en évidence par une approche globale revenant à demander aux managers ce qu'ils redoutent le plus ou ce qui représente pour eux un souci majeur.

La description des dysfonctionnements, sera donc obtenue lors d'une réunion avec les managers.

7.2. Analyse de la gravité des dysfonctionnements identifiés

La deuxième sous-étape vise à déterminer la gravité des dysfonctionnements précédemment identifiés.

Dans MEHARI, la gravité des conséquences d'un risque est appelée « Impact ». Nous parlerons donc dorénavant de l'impact des dysfonctionnements.

Il faut donc, pour cela, faire référence à une échelle d'impact standard.

7.2.1 Critères d'impact et seuils d'impact

Les dysfonctionnements identifiés n'ont pas forcément une gravité unique. Au contraire, dans de nombreux cas, les dysfonctionnements doivent être caractérisés par un ou plusieurs paramètres déterminants pour leur gravité.

Par exemple, le retard dans l'accomplissement d'une activité ou d'une tâche est un dysfonctionnement dont la gravité dépend, très généralement, de la durée de ce retard, d'une part, et du nombre de personnes concernées par le retard, d'autre part.

Il peut donc être utile de déterminer, pour chaque dysfonctionnement, quels sont les paramètres significatifs et quels sont les seuils de ces paramètres qui font passer le dysfonctionnement d'un niveau d'impact à un autre.

7.2.2 Tableau des dysfonctionnements

Au besoin, pour faciliter la détermination des niveaux d'impacts, on suggère d'établir une échelle de valeurs (ou de seuils) qui aidera à déterminer les différents niveaux. Par exemple, dans le tableau suivant, on peut voir un exemple d'échelle de niveaux possibles avec les seuils permettant de passer d'un niveau à l'autre, tels qu'établis par un responsable de l'activité de gestion des Ressources Humaines. La première colonne à gauche indique les dysfonctionnements tandis que la première ligne indique les niveaux. Les seuils indiquant comment passer d'un niveau à l'autre apparaissent à droite dans les cellules à droite de chaque dysfonctionnement.

Dysfonctionnement	***Niveau 1*** ***Non significatif***	***Niveau 2*** ***Important***	***Niveau 3*** ***Très Grave***	***Niveau 4*** ***Vital***
Falsification des données de paye conduisant à une fraude	Perte < 0.1 M€	Perte comprise entre 0.1 M€ et 1 M€	Perte comprise entre 1 et 10 M€	Perte > 10 M€

Divulgation d'informations sur des données personnelles	Divulgation du salaire d'un employé	Divulgation des salaires de l'ensemble du personnel	Divulgation répétée des salaires du personnel	
Retard dans le paiement des salaires	Retard < 2 jours	Retard compris entre 2 et 15 jours	Retard > 15 jours	
Destruction des données de base concernant le règlement de la paye (calcul et paramétrage)	Effacement des données récentes (moins d'un mois)	Effacement des données de l'année	Destruction des données et de tout l'historique	

L'échelle de valeurs constituée n'est ainsi rien d'autre que le rassemblement dans un document unique de l'ensemble des types de dysfonctionnement et des seuils de criticité.

En partant de ce tableau, les manager devront choisir en fonction du niveau indiqué les dysfonctionnements qui devront faire l'objet d'une analyse de risques spécifique. Une instance de la base devra être créée pour chaque dysfonctionnement à analyser.

7.2.3 Démarche

La recherche du niveau d'impact des dysfonctionnements sera faite lors de la réunion avec les managers.

Les résultats consisteront ainsi en une description des dysfonctionnements redoutés, pour chaque activité identifiée, et en une évaluation de l'impact de ces dysfonctionnements, en fonction des critères d'impact.

8. Détermination du cadre technique de l'analyse des risques

Les objectifs de la deuxième étape de la démarche sont de passer du cadre fonctionnel au cadre technique dans lequel il sera possible de faire une analyse des risques potentiels.

En effet, les mécanismes employés dans l'appréciation et la gestion des risques, de même que certains choix de solutions ou d'élaboration de plans d'action, nécessitent que ces dysfonctionnements, exprimés initialement en termes liés à l'activité, soient traduits en termes techniques relatifs à des ressources du Système d'Information, regroupées sous l'appellation d'« actifs ».

Il s'agit, par exemple, de la perte de confidentialité de telle base de données applicative, ou de l'indisponibilité de tel serveur, etc.

Cette étape, communément appelée « ***Classification des actifs*** », revient à rechercher s'il existe des actifs dont un « défaut » pourrait conduire à l'un des dysfonctionnements identifiés précédemment.

Pour ce faire, la démarche consiste à :

- Préciser le cadre fonctionnel de l'analyse
- Considérer chaque actif primaire parmi une liste type

- Considérer chaque critère de défaut pour cet actif
- Répondre à la question : « ce défaut, de cet actif, peut-il conduire à un des dysfonctionnements redoutés ? »
- Préciser alors, en cas de réponse positive à la question précédente : « quel serait alors le niveau maximal d'impact de ce ou de ces dysfonctionnements ? »
- Établir, in fine, les tableaux d'impact intrinsèque qui fixeront le cadre technique utilisé pour l'analyse des risques

8.1. Précision du cadre fonctionnel de l'analyse

Le cadre naturel de MEHARI–Standard est celui de l'analyse des risques de plusieurs activités, tel que cela a été décrit plus haut. On raisonnera donc, par un processus itératif, pour chaque domaine d'activité.

8.2. Liste et typologie des actifs primaires

Ainsi que cela a été présenté plus haut dans ce document, les actifs primaires correspondent aux **besoins** des organisations que l'on peut classer dans trois catégories :

- Les services (informatiques, de télécommunication et généraux),
- Les données nécessaires au fonctionnement des services,
- Les processus de management.

A l'intérieur de ces catégories, il a été établi une liste plus précise d'actifs primaires et la liste de Manager-Standard est indiquée en annexe.

8.3. Critères de défaut, ou critères de classification

Remarquons, tout d'abord, que la survenance d'un défaut est exactement ce que nous avons appelé ***« incident »*** dans le modèle de risque.

Les données informatiques peuvent être à l'origine d'un dysfonctionnement pour trois raisons principales : la perte de disponibilité, d'intégrité ou de confidentialité.

Pour les services, il s'agit essentiellement de la perte de disponibilité ou d'intégrité, mais il peut aussi s'agir de confidentialité pour certaines applications représentant un avantage concurrentiel pour l'entité.

Pour les processus de management vis-à-vis des principes de gouvernance et de prise de décision ou, vis-à-vis du respect de la réglementation ou des exigences contractuelles, le critère de défaut est la perte d' « Efficience ».

Les critères de défaut sont donc la perte de disponibilité, d'intégrité, de confidentialité ou d'efficience (critères notés D, I, C ou E dans les tableaux d'impact intrinsèque qui seront décrits plus loin.

8.4. Processus de classification

Pour chaque domaine d'activité et pour chaque type d'actif primaire, une analyse sera faite pour déterminer si une perte de disponibilité de ce type d'actif est susceptible de conduire au dysfonctionnement redouté et, si oui, à quel niveau d'impact. Ce niveau est le niveau de classification recherché pour le critère de disponibilité.

Il sera fait de même pour les autres critères, d'intégrité, de confidentialité et d'efficience pour aboutir, in fine et pour chaque type d'actif, à 1, 2 ou 3 valeurs de classification, une par critère pertinent (Disponibilité, Intégrité, Confidentialité, pour actifs de type service ou données, Efficience pour les actifs de type Processus de management).

8.5. Élaboration des tableaux d'impact intrinsèque

Le tableau d'impact intrinsèque, qui fixe le cadre de l'analyse des risques, doit être renseigné et établi dans les feuilles Excel T1, pour les actifs de type « Données », et T2, pour les actifs de type « Services » ou « Processus de management ».

8.5.1 Élaboration des tableaux d'impact intrinsèque T1 et T2

L'élaboration du tableau d'impact intrinsèque se fait simplement en renseignant, pour chaque actif primaire et pour chaque critère de classification, l'impact maximal pouvant être atteint.

Ceci se fait dans les tableaux T1 et T2

Tableau T1			CLASSIFICATION DES DONNÉES																			
Processus métier, domaine applicatif ou domaine d'activité Services communs à particulariser	FONCTION (descriptif)	Sélection si 1	Données applicativ. (bases de données)			Fichiers bureaut.			Inform. Écrite ou imprimée			Courrier postal ou électronique			Archives, document. ou informat.		Données publiées (web ou interne)		Données externalisées sur le cloud		
			D	I	C	D	I	C	D	I	C	D	I	C	D	C	D	I	D	I	C
Types d'actifs =>			D01	D01	D01	D02	D02	D02	D04	D04	D04	D05	D05	D05	D06	D06	D06	D06	D07	D07	D07
Processus métiers																					
Domaine 1 : Développement produits		0						3						3					4		
Domaine 2 : Marketing		1		2	3																
Domaine 3 : Achats et fournisseurs		1				1	1	3			3			3							
Domaine 4 : Commercial		1				3	3	3			3		3	3							
Domaine 5 : Logistique		1																			
Domaine 6 : Comptabilité - Finances		1																			
Domaine 7 :		1																			
Domaine 8 :		1																			
Domaine 9 :		1																			
Domaine 10 :		1																			
Processus transverses		1																			
Processus 1 :		1																			
Processus 2 :		1																			
Processus 3 :		1																			
Administration/ politique d'ensemble		1																			
Classification d'ensemble			4	3	3	3	3	3			3		3	3					4		
Classification pour les activités sélcionnées			4	3	3	3	3	3			3		3	3							

Section pour indiquer les niveaux d'impacts

Il faut porter une attention particulière afin de ne sélectionner que les actifs primaires qui, en cas de survenance du type de défaut (perte de disponibilité, d'intégrité, de confidentialité ou d'efficience) conduiront au dysfonctionnement redouté. Il y a une différence notable entre indiquer un impact

intrinsèque de niveau 1 (non significatif) et laisser une case vide (ou supprimer toute valeur dans cette case) : dans le premier cas, des fiches de risque seront proposées à l'analyse (avec un impact non significatif) alors que dans le second, il n'y aura pas de risque à analyser pour cet impact et ce type de conséquence.

On notera aussi que ces tableaux laissent quelques lignes pour des processus transverses qui ne sont pas rattachés à une activité métier (la DSI, par exemple).

8.5.2 Élaboration du tableau de synthèse « Classif »

Un tableau de synthèse est établi automatiquement dans la feuille « Classif », tel que représenté ci-dessous.

Tableau d'Impact Intrinsèque						
Actifs de type Données et informations			**D**	**I**	**C**	**E**
Données et informations						
D01	Données applicatives	Données contenues dans des fichiers ou bases de données utilisés par les appplications	4	3	3	
D02	Données bureautiques	Données contenues dans des fichiers personnels ou partagés, incluant les fichiers d'agenda ou de contacts	3	3	3	
D03	Informations écrites ou imprimées	détenues par les utilisateurs, archives personnelles, listings et états imprimés issus des applications informatiques, et la documentation des processus et autres actifs pouvant être nécessaire à l'activité.			3	
D04	Courrier électronique ou postal	Courrier électronique, postal ou télécopies		3	3	
D05	Archives	patrimoniales, documentaires ou informatiques				
D06	Données et informations publiées	sur des sites publics ou internes				
D07	Données externalisées	sur le cloud				
Actifs de type Processus (Services)			**D**	**I**	**C**	
Services des technologies de l'information						
S01	Services applicatifs	applications métiers, services bureautiques ou systèmes communs	4	3		
S02	Services externalisés	ou hébergés sur le cloud	4			
S03	Services de publication d'informations	sur un site web interne ou public				
Processus de management						
P01	Processus de gestion de la conformité	aux exigences légales ou contractuelles ou de l'entité				3
P02	Processus de gouvernance et de prise de décision	dans la gouvernance de l'entité (pouvant conduire à un dysfonctionnement redouté) y compris la gouvernance de la sécurité				

9. Diagnostic de l'état des services de sécurité

Le diagnostic de l'état des services de sécurité est l'étape qui va permettre de porter un jugement su les mesures de réduction des risques pertinentes pour chaque scénario de risque.

MEHARI Standard comprend une base de connaissance de services de sécurité comprenant des questionnaires de diagnostic organisés par domaines de responsabilité.

Cette organisation par domaine permet d'avoir des questionnaires séparés en fonction des interlocuteurs à rencontrer pour faire le diagnostic.

Ces domaines sont :

- Un domaine relatif à l'organisation de la sécurité
- Un domaine traitant de la sécurité physique

- Un domaine relatif à l'infrastructure informatique (systèmes et réseaux)
- Un domaine relatifs à l'administration et l'exploitation de l'infrastructure
- Un domaines relatif à la sécurité applicative
- Un domaine traitant des postes de travail utilisateurs
- Un domaines relatif aux développements
- Un domaine relatif aux processus de management

9.1. Système de mesure de la qualité des services de sécurité

Le système de mesure de la qualité des services de sécurité de MEHARI est basé sur un système de cotation des réponses aux questions, **questions auxquelles il est demandé de répondre par oui ou par non**, avec des conventions de cotation et de pondération qui sont décrites en détail dans le document « Guide du diagnostic de l'état des services de sécurité », disponible sur le site du Clusif.

9.2. Processus de diagnostic

Avant de décrire le processus de diagnostic proprement dit, il est nécessaire d'aborder une question préliminaire qui a trait aux services à diagnostiquer. Il peut, en effet, exister plusieurs variantes du même service et il peut être nécessaire d'en tenir compte

9.2.1 Le schéma d'audit

Les services de sécurité tels que décrits dans MEHARI sont des fonctions de sécurité et ces fonctions sont assurées par des **solutions** effectivement mises en place dans l'entreprise ou l'organisme.

Le diagnostic de l'état de la sécurité consiste, en pratique, à analyser ou auditer les solutions ainsi que les procédures mises en place pour assurer les fonctions de sécurité.

Cependant, il existe généralement, dans la même entreprise, plusieurs solutions pour assurer la même fonction générale.

Par exemple, le contrôle d'accès aux locaux est certainement assuré par des mécanismes différents et avec des solutions différentes pour l'accès aux salles informatiques, l'accès aux baies de répartition des lignes téléphoniques, l'accès aux salles de conférence et l'accès aux salles techniques contenant les gros équipements d'alimentation électrique.

Des développements sur ce schéma d'audit sont décrits dans le document cité ci-dessus.

A ce stade, ce qu'il faut noter est que les questionnaires de la base Excel ont prévu 4 colonnes de réponses, pour 4 variantes éventuelles et que dans la synthèse de diagnostic des services, si plusieurs réponses ont été données, ce sera, pour chaque service, le minimum des cotations des variantes.

9.2.2 Le processus de diagnostic proprement dit

Puisque les questionnaires d'audit des services de sécurité sont précisément organisés en fonction des domaines de responsabilité, il suffira, une fois défini le schéma d'audit, de collecter les réponses

correspondant à chaque variante auprès de la personne ou du groupe de personnes le mieux placé pour cela.

Par ailleurs, en ce qui concerne l'usage des questionnaires, les réponses par oui ou par non peuvent, dans certains cas, poser des difficultés, les réponses naturelles pouvant être :

- "Oui en général mais avec des exceptions"
- "Oui en théorie, mais, en pratique, ce n'est pas certain ou pas appliqué partout"
- "Oui partiellement, à X %"
- "Oui, en cours de déploiement"
- "Oui, c'est prévu mais non encore appliqué"
- etc.

Les recommandations suivantes peuvent être faites :

- Il faut impérativement noter les explications accompagnant les réponses et en garder la trace. C'est ainsi que dans les questionnaires papiers qui servent de support aux réunions d'audit, il importe de garder une colonne "Commentaires" dans laquelle la réponse précise sera notée.
- La cotation demandant une réponse "oui" ou "non", il faut prendre un parti. La position "sécuritaire" consisterait à répondre "non" à toutes les questions précédentes pour que les décisions qui découleront de l'audit n'occultent pas l'imperfection constatée.
- Il faut être conscient, néanmoins, que cela peut démotiver les utilisateurs et décrédibiliser l'audit si trop d'insistance est mise sur un point mineur en cours de correction et maîtrisé.
- La solution raisonnable semble ainsi être de répondre "Oui" chaque fois que le processus de correction et de réaction aux manquements ou de déploiement est sous contrôle et maîtrisé et de répondre "Non" dans le cas contraire.

Il est à noter que pour que de telles réponses puissent être saisies, il est absolument nécessaire que l'audit ait lieu lors d'une rencontre entre l'auditeur et le responsable du domaine audité et que les questionnaires soient remplis lors de cette réunion. Les questionnaires remplis par la personne auditée en dehors de la présence de l'auditeur masquent totalement cet aspect des réponses et peuvent introduire des biais sérieux dans la qualité de l'audit.

9.2.3 Questions sans objet

Certaines questions peuvent être « sans objet » pour certaines unités. Dans ce cas, le fait de remplir « X » dans la colonne réponse suffit à faire que la question ne soit pas prise en compte.

Il conviendra de faire très attention cependant à ce qu'une question sans objet doit le rester quelles que soient les évolutions prévisibles du système d'information et des services de sécurité.

Il est également possible d'indiquer par un « X » en tête des questions d'un service, que ce service n'existe pas ou n'a pas de raison d'être dans l'organisme (il n'y aura alors aucune cotation du service).

9.3. La synthèse par services de sécurité

La synthèse de la qualité des services de sécurité se trouve dans la feuille « Services » de la base de connaissances.

Au cas où des variantes ont été définies, le résultat qui apparait dans cette présentation est le minimum des variantes.

A partir de là, le diagnostic final peut être présenté sous diverses formes de graphique : ces présentations sont laissées à l'initiative des utilisateurs.

9.4. Fournitures d'indicateurs relatifs à la norme ISO/IEC 27002:2022

Ainsi qu'il a été indiqué dans le document « *MEHARI Principes fondamentaux et spécifications fonctionnelles* », le diagnostic de sécurité peut servir également à exprimer le niveau de maturité de l'organisation considérée vis à vis des bonnes pratiques de la norme ISO/IEC 27002:2022.

En effet, chaque question de l'audit MEHARI peut être vue comme un point de contrôle élémentaire destiné à vérifier les solutions et les processus de sécurité mis en œuvre par l'entité.

Comme l'organisation de l'audit MEHARI permet d'obtenir, auprès de chaque responsable opérationnel concerné, la capacité de l'entité à réduire les risques, la structure des services ne se plie pas directement à la structure « descriptive » de la norme.

De plus, les questionnaires de MEHARI comportent plusieurs services et contrôles allant au-delà des recommandations de la norme, il a été nécessaire de réaliser une extraction et un transcodage parmi les questions de l'audit MEHARI vers les pratiques de la norme ISO.

Les questionnaires d'audit de MEHARI permettent ce transcodage et une table de correspondance (avec les formules nécessaires) est fournie dans la base de connaissances.

Ainsi, il est possible de visualiser le niveau de maturité de l'entité (avec un score de 0 à 10, par exemple) pour chaque point de contrôle de la norme. Il ne s'agit pas de l'objectif primaire de MEHARI mais cela peut constituer une information utile lors d'un processus de certification ou d'une comparaison entre plusieurs organisations.

10. Paramétrages de l'analyse des risques

L'objectif de cette étape est de procéder au contrôle des paramètres standards proposés par la base de connaissance Standard et aux ajustements éventuellement jugés souhaitables.

10.1. Désélection d'activités prises en compte pour la classification

Une fois les tableaux T1 et T2 remplis, il est possible, pour une analyse plus ciblée, de désélectionner une ou plusieurs activités, dans la feuille T1 (cette désélection sera reportée dans T2).

Pour désélectionner une activité, il faut simplement l'indiquer par un « 0 » (à la place d'un « 1 » en version de base) dans la section « Sélection » de l'onglet « T1 », tel qu'illustré par la capture d'écran suivante.

Tableau T1			CLASSIFICATION DES DONNÉES																		
Processus métier, domaine applicatif ou domaine d'activité Services communs à particulariser	FONCTION (descriptif)	Sélection si 1	Données applicativ. (base de données)			Fichiers bureaut.			Inform. Écrite ou imprimée			Courrier postal ou électronique			Archives, document. ou informat.		Données publiées (web ou interne)		Données externalisées sur le cloud		
			D	I	C	D	I	C	D	I	C	D	I	C	D	C	D	I	D	I	C
Types d'actifs =>			D01	D01	D01	D02	D02	D02	D04	D04	D04	D05	D05	D05	D06	D06	D06	D06	D07	D07	D07
Processus métiers																					
Domaine 1 : Développement produits		0						3						3					4		
Domaine 2 : Marketing		1		2	3																
Domaine 3 : Achats et fournisseurs		1				1	1	3			3			3							
Domaine 4 : Commercial		1				3	3	3			3		3	3							
Domaine 5 : Logistique		1	4	2																	
Domaine 6 : Comptabilité - Finances		1	2	3																	
Domaine 7 :		1																			
Domaine 8 :		1																			
Domaine 9 :		1																			
Domaine 10 :		1																			
Processus transverses		1																			
Processus 1 :		1																			
Processus 2 :		1																			
Processus 3 :		1																			
Administration/ politique d'ensemble		1																			
Classification d'ensemble			4	3	3	3	3	3			3		3	3					4		
Classification pour les activités sélcionnées			4	3	3	3	3	3			3		3	3							

Section pour la sélection

10.2. Désélection d'actifs primaires

De même, il est possible, pour une analyse plus ciblée, de désélectionner une ou plusieurs actifs primaires dans la feuille « Classif ».

Pour désélectionner un actif primaire, il faut simplement l'indiquer par un « 0 » (à la place d'un « 1 » en version de base) dans la section « Sélection » de l'onglet « Classif », tel qu'illustré par la capture d'écran suivante.

Tableau d'Impact Intrinsèque							Sélection d'actifs
Actifs de type Données et informations			D	I	C	E	
Données et informations							
D01	Données applicatives	Données contenues dans des fichiers ou bases de données utilisés par les appplications	4	3	3		1
D02	Données bureautiques	Données contenues dans des fichiers personnels ou partagés, incluant les fichiers d'agenda ou de contacts	3	3	3		1
D03	Informations écrites ou imprimées	détenues par les utilisateurs, archives personnelles, listings et états imprimés issus des applications informatiques, et la documentation des processus et autres actifs pouvant être nécessaire à l'activité.			3		1
D04	Courrier électronique ou postal	Courrier électronique, postal ou télécopies		3	3		1
D05	Archives	patrimoniales, documentaires ou informatiques					1
D06	Données et informations publiées	sur des sites publics ou internes					1
D07	Données externalisées	sur le cloud					1
Actifs de type Processus (Services)							
Services des technologies de l'information							
S01	Services applicatifs	applications métiers, services bureautiques ou systèmes communs					1
S02	Services externalisés	ou hébergés sur le cloud					1
S03	Services de publication d'informations	sur un site web interne ou public					1
Processus de management							1
P01	Processus de gestion de la conformité	aux exigences légales ou contractuelles ou de l'entité				3	1
P02	Processus de gouvernance et de prise de décision	dans la gouvernance de l'entité (pouvant conduire à un dysfonctionnement redouté) y compris la gouvernance de la sécurité					1

Section pour la sélection

10.3. Désélection de types d'actifs support

Les actifs ont des vulnérabilités et ce sont elles dont l'exploitation conduit au risque.

Pour rechercher ces vulnérabilités, il est essentiel, cependant, de distinguer, pour chaque actif primaire :

- Les diverses formes qu'il peut revêtir,
- Les diverses contingences dont il peut dépendre.

Ces formes et contingences peuvent être regroupées sous l'appellation d'actifs secondaires ou ***d'actifs support***.

Autant les actifs primaires correspondent à des besoins fonctionnels, autant les actifs support correspondent à un niveau matériel et concret et aux moyens nécessaires à la réalisation des besoins fonctionnels.

La typologie des actifs support de MEHARI–Standard donnée en annexe.

Il n'y a dans la très grande majorité des cas, rien à modifier concernant les actifs support mais on peut envisager d'éviter des analyses inutiles en désélectionnant certains types d'actifs support. Ce peut être par exemple la désélection du courrier postal en transit si l'on ne souhaite pas considérer les risques liés au courrier postal dans l'analyse.

Pour désélectionner un actif support, il faut simplement l'indiquer par un « 0 » (à la place d'un « 1 » en version de base) dans la section « Sélection » de l'onglet « Actifs support, tel qu'illustré par la capture d'écran suivante.

Tableau des actifs support

	Nom	*Types d'actifs support*	*Sélection*	Mettre un 0 dans la colonne sélection pour ne pas sélectionner un actif support
Eléménts immatériels de type "données"	Fic	Fichier ou base de données	1	
	Det	Données en transit	1	
	Coe	Courriel en transit	1	
Eléments matériels supports de données (ou d'information)	Med	Media support de données	1	
	Doc	Document	1	
	Cop	Courrier en transit	1	
	Msa	Média support d'archive	1	
Eléments immatériels de type "services"	Cfg	Configuration systèmes et réseaux	1	
Eléments matériels supports de services	Equ	Equipement de l'Infrastructure informatique	1	
	Env	Environnement de travail et équipement des utilisateurs	1	
	Msl	Media support de logiciel	1	
Eléments mixtes de type "services"	Iml	Infrastructure matérielle et logicielle support de services externalisés	1	
Eléments immatériels de type "processus"	Pro	Procédure support des processus	1	

Section pour la sélection

10.4. Désélection des types de dommage

Les types de dommage décrivent la nature des dégâts matériels ou immatériels causés aux actif support.

Comme précédemment, il n'y a généralement rien à faire. On peut éventuellement souhaiter éliminer certains dommages de l'analyse.

Pour désélectionner un type de dommage, il faut simplement indiquer un « 0 » dans la section « Sélection » de l'onglet des types de dommage tel qu'illustré par la capture d'écran suivante.

Tableau d'analyse des types de dommages

Rappel
Ces dommages sont subis par des actifs secondaires (ou supports) qui peuvent être :
Des éléments matériels : équipement fonctionnel, câblage, dispositifs de sécurité, etc. des médias support de logiciel, d'automatisme, de paramètres de processus ou de données.
Des éléments immatériels : logiciel, automatisme, paramétrage de processus, etc. ou des données (fichiers constitués, données fugitives, messages, échanges audiovisuels, etc.)
Des procédures de management

Critère de sécurité impacté	*Type de conséquence*	*Nom*	*Type de dommage*	*Commentaires*	*Sélection*
Disponibilité	Indisponibilité	Inac	Inaccessibilité	L'élément est introuvable : absence d'adresse, adresse fausse ou service assurant l'adressage	1
		Disp	Disparition	L'élément est absent là où on le cherche (et pour un prestataire, il n'est plus opérationnel)	1
		Endp	Endommagement physique	Endommagement physique (détecté) rendant l'élément matériel non fonctionnel	1
		Endl	Endommagement logique	Endommagement logique(détecté) rendant l'élément non fonctionnel (programmes non fonctionnels, données incohérentes)	1
		Inop	Inopérabilité	L'élément reste, en lui même, fonctionnel mais ne peut être mis en opération pour des raisons exogènes (absence de personnel, de service indispensable au fonctionnement, etc.)	1
		Inex	Inexploitabilité	L'élément est sans dommage apparent mais non fonctionnel (panne, saturation, perte de performances rédhibitoires, etc.) ou inexploitable soit totalement (élément nécessaire absent : clé de chiffrement, licence, jeton d'accès, etc. ou) soit partiellement (dégâts dus à la pollution, au vieillissement, soit à cause d'un défaut de cohérence)	1
Intégrité	Défaut d'intégrité	Altd	Altération (non détectée) de donnée	Tout ou partie des données a été corrompue de manière accidentelle ou malveillante (que ce soit pour un ensemble structuré de données, des données isolées ou messages)	1
		Altf	Altération (non détectée) de fonction	Tout ou partie des fonctions a été altérée de manière accidentelle ou malveillante (fonctions logicielles, matérielles ou paramètres de fonctionnement)	1
		Inco	Incohérence (non détectée) de données	L'ensemble de données comporte des incohérences	1
		Crfx	Création de faux	Un élément nouveau et illégitime a été émis	1
Confidentialité	Divulgation	Dive	Divulgation de données	Tout ou partie de l'ensemble de données a été dupliqué, téléchargé, diffusé ou volé	1
Efficience des processus	Inapplication de procédures adaptées	Napp	Non application de la procédure adaptée	Les procédures adéquates n'ont pas été suivies par le personnel (par ignorance ou volontairement)	1

Section pour la sélection des types de dommage

10.5. Adaptation des niveaux d'exposition aux événements

Des valeurs standard d'exposition naturelle aux événements types pouvant déclencher l'occurrence d'un risque ont été établies par les concepteurs de Méhari. Dans la très grande majorité des cas, ces valeurs standard (appelées « Exposition naturelle standard CLUSIF ») reflètent bien la réalité des organisations d'aujourd'hui et sont donc suffisantes.

Cependant, Méhari offre la possibilité de changer ces valeurs si l'organisation juge que celles-ci ne reflètent pas sa réalité. Dans ce cas, l'utilisateur peut indiquer des valeurs différentes (appelées « Exposition naturelle décidée »). Par défaut, c'est la valeur de l'exposition naturelle standard du CLUSIF qui prévaut. Si une valeur est indiquée dans la colonne de l'exposition naturelle décidée, alors c'est cette valeur qui sera utilisée pour l'événement associé.

Tableau des événements : types et exposition naturelle

Type	*Code type*	*Événement*	*Exposition naturelle standard CLUSIQ*	*Code*	*Exposition naturelle décidée*	*Exposition naturelle résultante*	*Sélection si 1*
Absence de personnel	AB.P	Absence accidentelle de personnel interne ou de partenaire	3	AB.P.Per		3	1
Absence ou indisponibilité accidentelle de service	AB.S	Absence de services généraux : défaillance ou indisponibilité de services généraux ou de servitudes, énergie, climatisation, etc.	2	AB.S.Gen		2	1
		Absence de service : Impossibilité d'accès aux locaux	2	AB.S.Loc		2	1
		Absence de matériel compatible ou incompatibilité de systèmes	2	AB.S.Mat		2	1
		Absence de service : défaillance ou indisponibilité des services fournis par un prestataire externe	3	AB.S.Ser		3	1
Accident grave d'environnement	AC.E	Accident grave d'environnement : Incendie, Inondation, foudroiement, tremblement de terre,... ou dû à du terrorisme	2	AC.E.Evt		2	1
Accident matériel	AC.M	Panne ou dysfonctionnement d'équipement	3	AC.M.Equ		3	1

Exposition naturelle décidée

10.6. Désélection de types d'événements déclencheurs

Comme pour les actifs support ou les dommages, il est possible de désélectionner un ou plusieurs types d'événements déclencheurs.

Pour désélectionner un type d'événement, il faut simplement indiquer un « 0 » dans la section « Sélection » de l'onglet des événements déclencheurs, tel qu'illustré par la capture d'écran suivante.

Tableau des événements : types et exposition naturelle

Type	*Code type*	*Événement*	*Exposition naturelle standard CLUSIQ*	*Code*	*Exposition naturelle décidée*	*Exposition naturelle résultante*	*Sélection si 1*
Absence de personnel	AB.P	Absence accidentelle de personnel interne ou de partenaire	3	AB.P.Per		3	1
Absence ou indisponibilité accidentelle de service	AB.S	Absence de services généraux : défaillance ou indisponibilité de services généraux ou de servitudes, énergie, climatisation, etc.	2	AB.S.Gen		2	1
		Absence de service : Impossibilité d'accès aux locaux	2	AB.S.Loc		2	1
		Absence de matériel compatible ou incompatibilité de systèmes	2	AB.S.Mat		2	1
		Absence de service : défaillance ou indisponibilité des services fournis par un prestataire externe	3	AB.S.Ser		3	1
Accident grave d'environnement	AC.E	Accident grave d'environnement : Incendie, Inondation, foudroiement, ou dû à du terrorisme		AC.E.Evt		2	1
Accident matériel	AC.M	Panne ou dysfonctionnement d'équipement		AC.M.Equ		3	1

Section pour la sélection des types d'événement déclencheur

10.7. Grille d'acceptabilité des risques

La grille d'acceptabilité des risques est modifiable dans l'onglet « ***Gravité*** ».

Cette grille qui est parfois appelée « Grille d'aversion au risque », est l'outil essentiel de support des décisions relatives aux risques et il est fondamental qu'existe, à son sujet, un accord et un consensus au niveau des instances de décision.

La grille proposée conviendra le plus souvent mais sa validation ou son adaptation éventuelle doivent faire partie de l'étape préparatoire à l'analyse proprement dite des risques.

En cas de souhait de modification, il suffira de modifier, pour chaque couple Potentialité/Impact, le nouveau niveau de gravité de risque décidé.

Feuille de synthèse : Gravité globale des risques

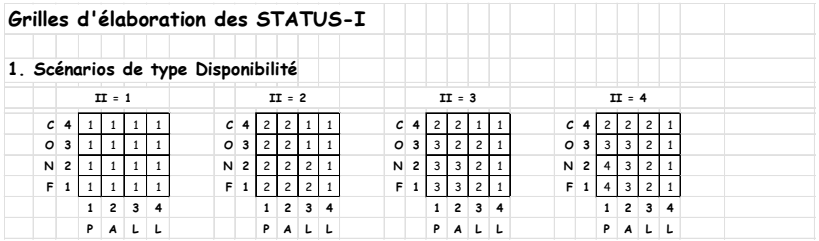
Impact				
4	2	3	4	4
3	2	3	3	4
2	1	2	2	3
1	1	1	1	2
	1	2	3	4
	Potentialité			

10.8. Grilles d'élaboration des Status-I et Status-P

Ces grilles de décision permettent d'estimer un impact résiduel et une potentialité résiduelle en fonction de l'impact intrinsèque, de la potentialité intrinsèque et des niveaux des mesures de réduction des risques.

Celles-ci peuvent être modifiées si l'utilisateur le juge souhaitable.

Voici une illustration partielle de l'onglet « Grilles_IP ».



11. État des risques

Le point de départ de la gestion des risques est la représentation que l'on peut se faire de l'état des risques.

Les risques, dans MEHARI sont matérialisés par des « scénarios de risque » qui sont décrits et analysés individuellement dans la feuille « Scénarios » et représentés globalement dans les feuilles Risk%actif et Risk%event.

Pour chaque scénario de risque l'état du risque est évalué, par la base de connaissance, en prenant en compte l'état des services de sécurité.

Que ce soit individuellement ou globalement, MEHARI permet d'afficher la gravité des risques selon plusieurs options :

- Gravité des risques intrinsèques, c'est-à-dire sans tenir compte des mesures de sécurité déjà en place et donc sans tenir compte de l'audit des services de sécurité.
- Gravité des risques actuels tenant compte des services de sécurité et de leur qualité telle qu'elle résulte de l'audit effectué
- Gravité des risques à terme, tenant compte de toutes les mesures prévues (plans envisagés et projets décidés)
- Gravité des risques à une date donnée tenant compte des projets planifiés (nouvelles mesures ou améliorations de services existants) achevés à cette date.

11.1. Sélection des options de gravité des risques

Les modes de sélection de ces options se fait, dans MEHARI–Standard, par des boutons à option prévus dans un cadre de la feuille Risk%actif :



C'est ainsi que la gravité calculée de chaque scénario de risque telle qu'elle apparait dans la feuille « Scénarios » colonne « Gravité calculée » est fonction de l'option choisie[5].

Les gravités de l'ensemble des scénarios est ensuite reportée dans diverses vues d'ensemble ou « panoramas » présentés ci-dessous.

11.2. Panoramas des risques

La vue d'ensemble de l'état des risques est présentée dans la feuille Risk%actif selon deux modes : un mode global et un mode par famille de scénarios.

Le mode global indique le nombre de scénarios de risque par niveau de potentialité et d'impact, sur la grille qui a servi à définir « l'acceptabilité des risques ».

Il est situé sous le cadre de sélection d'options de gravité et est présenté ci-dessous :

Panorama des risques
résultant de l'option définie ci-dessus

Impact				
4	0	6	5	0
3	0	37	58	0
2	0	17	27	0
1	1	21	33	0
	1	2	3	4
			Potentialité	

La feuille Risk%actif donne également un panorama par famille de scénarios, dans lequel n'apparaissent pas de manière séparée les paramètres I et P du risque, mais, par contre, l'indicateur de disponibilité, d'intégrité, de confidentialité ou d'efficience pour les processus de management.

[5] On notera que, dans la feuille « Services », l'objectif de chaque service (colonne I) est fonction de cette option et que c'est en partant de ces valeurs d'objectifs de services de sécurité qu'est calculée la gravité de tous les scénarios de risque

Panorama des gravités de scénarios		Disponibilité					Intégrité					Confidentialité				
Actifs de type Données		N. 1	N. 2	N. 3	N. 4		N. 1	N. 2	N. 3	N. 4		N. 1	N. 2	N. 3	N. 4	
DAP	Données applicatives	0	0	3	14	>	0	0	10	0	>	0	0	7	0	>
DBU	Données bureautiques	0	0	15	1	>	0	0	7	0	>	0	0	15	1	>
IEI	Informations écrites ou imprimées	0	0	0	0	>	0	0	0	0	>	0	0	5	0	>
CEP	Courrier électronique ou postal	0	0	0	0	>	0	0	3	0	>	0	0	3	0	>
ARC	Archives	0	0	0	0	>						0	0	0	0	>
DPU	Données et informations publiées	0	0	0	0	>	0	0	0	0	>					
DEX	Données externalisées	0	0	0	0	>	0	0	0	0	>	0	0	0	0	>
Actifs de type Services																
SAP	Services applicatifs	0	0	13	16	>	0	0	12	0	>	0	0	0	0	>
SEX	Services externalisés ou hébergés sur le cloud	0	0	0	2	>	0	0	0	0	>					
SPU	Services de publication d'informations sur un site web interne ou public	0	0	0	0	>	0	0	0	0	>					
Processus de management		Efficience														
PGC	Processus de gestion de la conformité	0	0	3	0	>										
PGD	Processus de gouvernance et de prise de décision	0	0	0	0	>										
	Nombre de scénaios par niveaux de gravité :	0	0	34	33		0	0	32	0		0	0	30	1	
	Nombre total de scénarios, hors scénarios évités, transférés ou acceptés : 130															

Image issue de Standard 2017

Notons enfin qu'un troisième panorama est fourni dans la feuille Risk%event. Il indique le nombre de scénarios de niveau de gravité 1, 2, 3 ou 4 pour chaque type d'événement déclencheur.

12. Le traitement des risques

Comme nous l'avons présenté dans le *Guide de l'analyse et du traitement des risques*, le traitement des risques consiste à analyser chaque scénario de risque et à prendre des décisions spécifiques qui peuvent être de :

- Réduire le risque c'est-à-dire prendre des mesures pour que l'impact ou la potentialité ou les deux soient réduits et diminuent la gravité résiduelle en conséquence
- Décider d'éviter le risque en supprimant la situation de risque par des mesures structurelles ou organisationnelles
- Transférer le risque, essentiellement par l'assurance
- Accepter le risque tel quel

12.1. Réduction des risques par « Projets de sécurité »

Pour la réduction des risques, MEHARI et plus particulièrement la base *Standard* propose de travailler par « projets ».

Un projet comprend un ou plusieurs services de sécurité, avec pour les services inclus dans le projet, un objectif cible de qualité (comprenant l'efficacité du service, sa robustesse et sa mise sous contrôle).

Il s'agit généralement d'un ensemble de services qu'il est cohérent de traiter ensemble.

MEHARI-Standard comprend ainsi une cinquantaine de projets prédéfinis qui peuvent être visionnés dans la feuille « Des_projets ».

La planification et la gestion de la réduction des risques consiste ainsi à :

- Sélectionner ou présélectionner un ensemble de projets décrits dans la base de connaissances
- Vérifier qu'avec la mise en place de ces projets, les risques à réduire sont bien ramenés à un niveau acceptable
- Décider quels projets seront engagés et les budgéter
- Planifier ces projets en déterminant une date de début et une date de fin
- Suivre l'avancement des projets et réagir le cas échéant grâce à des outils de pilotage

Les aides fournies par MEHARI–Standard dans ce processus sont décrites ci-dessous.

12.2. Sélection de projets dans MEHARI–Standard

Les projets sont décrits dans la feuille « Projets » qui est la feuille de référence. Si l'utilisateur souhaite modifier certains projets (en particulier la cible des services de sécurité) c'est dans cette feuille qu'il convient de le faire.

12.2.1 Sélection de projets par famille de scénarios

Une première approche consiste à travailler par famille de scénarios qui regroupe les scénarios ayant le même type d'impact et le même actif primaire.

Pour chaque famille, des projets sont proposés, dans la feuille Plans_action, avec, pour chaque projet, un code, un descriptif d'ensemble, les services impliqués dans le projet et, pour chaque service, un niveau cible à l'issue du projet.

Une colonne permet de sélectionner (ou présélectionner) le projet, de même qu'une autre colonne indique si le projet a déjà été sélectionné au titre d'une autre famille de scénarios ou si le projet a déjà été décidé.

Exemple de famille de scénarios :

Sélection de projets

Famille de scénarios	Nombre de scénarios								
	Gr 1	Gr 2	Gr 3	Gr 4	Total		Projets	*Etat du projet*	Sélection
DAPD	**Perte de fichiers ou de bases de données applicatives**								
	0	0	3	14	17	CALO	Contrôle des accès aux locaux sensibles		
						CASA	Contrôle d'accès aux systèmes et applications	*Décidé*	
						CERD	Contrôle de l'émission et de la réception de données ou de messages		
						CODI	Contrôles des données sur incidents		
						COMA	Contrôle des opérations de maintenance	*Sélectionné*	1
						GMAF	Gestion des moyens d'accès aux fichiers de données ou de programme		
						SADC	Sauvegardes des données et configurations (non externalisées)		
						SMED	Sécurité physique des media support de données		
						SUAI	Surveillance des activités internes		
						SULO	Surveillance des locaux sensibles		

Image issue de Standard 2022

On notera que pour chaque famille, il y a une récapitulation du nombre de scénarios de la famille par niveau de gravité (toujours en fonction de l'option choisie).

Si l'option de prise en compte des projets sélectionnés ou décidés pour l'appréciation des risques a été choisie, la sélection d'un projet dans la feuille Plans_action permet de simuler les niveaux de gravité des scénarios de risque à l'issue de ces projets et donc d'aider à la décision de retenir ou non ce projet.

Dès lors, le processus consiste à

- sélectionner pour chaque famille les projets efficaces pour réduire les risques de ce domaine
- valider l'ensemble de ces sélections de projets : il convient alors, de les faire passer, dans la feuille Projets, du statut de « sélectionné » au statut de « décidé »
- éventuellement modifier, dans la feuille Projets, les cibles fixées aux services cités dans les projets décidés et recommencer le processus

Remarque : Dans cette approche par domaine de scénarios, un même projet peut apparaître dans plusieurs domaines. Afin de faciliter la tâche, l'état d'un projet est mentionné, dans la feuille Plans_action, à droite de la description littérale du projet, par une mention « sélectionné », sans mention, voire par une mention « refusé », s'il a été refusé au titre d'un domaine de scénarios[6].

[6] Dans le cas où un projet a été refusé dans un domaine de scénario, cette décision prévaut sur les autres possibilités de sélection : il est alors possible de voir dans un domaine de scénario une proposition de sélection d'un projet, à côté de la mention « refusé »

12.2.2 Sélection globale des projets

Il est également possible de procéder à une sélection globale des projets en choisissant par priorité, ce qui semble normal, les projets qui réduisent à un niveau acceptable (1 ou 2) le maximum de scénarios de risque.

A cet effet, MEHARI–standard propose une aide globale à la sélection, dans la feuille « Sel_Projets », sous la forme de deux tableaux qui font apparaître les projets prioritaires :

- Le tableau Tab-1 comprend les 5 projets qui réduisent le plus de risques de niveau 4 et indique, pour chaque projet, les domaines de scénarios concernés, le nombre de risques de niveau 4 réduits par domaine et le nombre de total de risques de niveau 4 réduits. Le tableau indique également l'influence du projet sur les risques de niveau 3 (augmentation ou réduction et combien).
- Le tableau Tab-2 comprend les 5 projets qui réduisent le plus de risques de niveau 3 et indique, pour chaque projet, les domaines de scénarios concernés, le nombre de risques de niveau 3 réduits par domaine et le nombre de total de risques de niveau 3 réduits.

Sélection de projets — Actualiser

Tab-1	Projets réduisant le nombre de risques de niveau 4																
Code projet	Libellé	Nb de risques de niveau 4 réduits													Total	Impact sur risques de niveau 3	
																Type d'impact	Nb de risques touchés
SADC	Sauvegardes des données et configurations (non externalisées)	DAPD	6	DBUD	1	SAPD	2								9	Réduction	10
GMAF	Gestion des moyens d'accès aux fichiers de données ou de programme	DAPD	3	SAPD	3										6	Réduction	6
COPR	Contrôle des programmes	SAPD	5												5	Réduction	2
SULO	Surveillance des locaux sensibles	DAPD	1	SAPD	4										5	Augmentation	3
PMAL	Protection contre les malwares et actions malveillantes (hameçonnage)	DBUD	1	DBUC	1	SAPD	1								3	Réduction	4

Tab-2	Projets réduisant le nombre de risques de niveau 3													
Code projet	Libellé	Nb de risques de niveau 3 réduits												
		Dom	Nb	Dom	Nb	Dom	Nb	Dom	Nb	Dom	Nb	Dom	Nb	Total
PDSS	Protection des documents et supports sensibles	DBUD	4	IEIC	4									8
PPDT	Protection du poste de travail	DBUI	1	DBUC	2	SAPI	3							6
CHED	Chiffrement des échanges de données	DAPI	2	DAPC	1	DBUI	2	DBUC	1					6
CHDA	Chiffrement des données applicatives stockées	DAPI	2	DAPC	2									4
SMEL	Sécurité des mails et des messages électroniques	CEPI	2	CEPC	2									4

Il est ainsi possible de procéder progressivement pour sélectionner les projets les plus efficaces, au moins jusqu'à un stade où, quand il ne reste qu'un nombre limité de risques à réduire, il devient peut-être plus facile de raisonner par domaine de scénario pour analyser si les quelques risques restants doivent être réduits, acceptés, évités ou transférés.

12.2.3 Navigation entre les différentes feuilles de la base de connaissance

Les diverses feuilles citées comprennent des liens hypertextes qui permettent de naviguer entre elles :

- Les tableaux Tab-1 et Tab-2 de sélection globale des projets incluent les liens hypertextes vers la feuille projets pour sélectionner, le cas échéant, le projet concerné, ainsi que des liens vers les domaines de scénarios.
- Les domaines de scénarios incluent pour chaque type et chaque critère de classification des liens vers le domaine considéré dans la feuille « Scénarios »

12.2.4 Décision finale des projets à lancer et planification

A l'issue du processus décrit ci-dessus, il restera à finaliser la sélection en prenant la décision de lancer les projets sélectionnés, ce qui peut nécessiter une phase d'analyse plus poussée des solutions techniques et des budgets requis.

Il convient alors de marquer les projets décidés comme tels dans la colonne D de la feuille « Projets ».

Ensuite on pourra passer à l'étape de planification, nécessaire pour le suivi d'une part, mais aussi pour avoir une vision de l'état des risques en fonction du temps.

A cet effet, MEHARI–Standard propose, dans la feuille Projets, deux colonnes dans lesquelles on peut inscrire les dates prévues de début et de fin de chaque projet.

12.3. Traitement des risques non réduits

Ainsi que présenté dans le Guide de l'analyse et du traitement des risques, il se peut qu'à l'issue de la phase de sélection et de décision des projets à lancer, il reste des risques non réduits qu'il faudra accepter en l'état, éviter ou transférer.

Il importe, pour ces cas que cette décision soit reportée dans la base de connaissances. Cela se fait dans la colonne AA (Standard 2022) de la feuille « Scénarios ». Les risques acceptés, évités ou transférés n'apparaîtront plus dans les panoramas mais resteront mentionnés dans le tableau de bord présenté ci-dessous.

13. Indicateurs de suivi et tableau de bord

MEHARI–Standard comprend une feuille « Tbord » qui affiche deux tableaux :

— Un tableau de bord global représentant, dans sa partie haute, le nombre de risques par niveau de gravité.

Tableau de bord Actualiser

Nombre de scénarios de risque, par niveau

	Niveau 1	*Niveau 2*	*Niveau 3*	*Niveau 4*
Risques intrinsèques	**0**	**0**	**72**	**133**
Risques actuels	**0**	**36**	**70**	**99**
Risques réduits, à l'issue de tous les plans retenus	**33**	**50**	**52**	**70**
Risques acceptés	0	**0**	**1**	**1**
Risques évités	0	**0**	**1**	**1**
Risques transférés	0	**0**	**0**	**1**

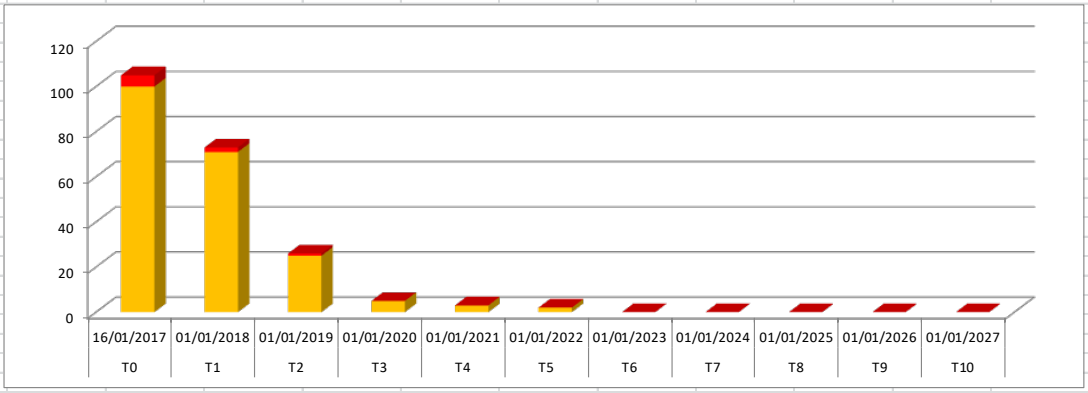
Dans ce tableau on a reporté les risques évités, transférés ou acceptés.

— Un tableau de bord de l'évolution du nombre de risques, par niveau de gravité, en fonction du temps.

Evolution des risques par années

En fonction des projets planifiés

	16/01/2017	01/01/2018	01/01/2019	01/01/2020	01/01/2021	01/01/2022	01/01/2023	01/01/2024	01/01/2025	01/01/2026	01/01/2027
Nombre de risques de niveau 4	5	2	1	0	0	0	0	0	0	0	0
Nombre de risques de niveau 3	100	71	25	5	3	2	0	0	0	0	0



Annexes

14. Annexe 1 : Actifs primaires

Les actifs primaires définis pour MEHARI–Standard sont :

- Pour les données et informations :
  - Les Données applicatives
  - Les Données bureautiques
  - Les Informations écrites ou imprimées
  - Le Courrier postal ou électronique
  - Les Archives
  - Les Données et informations publiées
  - Les Données externalisées
- Pour les services informatiques
  - Les Services applicatifs
  - Les Services externalisés
  - Les Services de publication d'informations
- Pour les processus de management
  - Les Processus de gestion de la conformité
  - Processus de gouvernance et de prise de décision

15. Annexe 2 : Actifs support

Les actifs support définis pour MEHARI–Standard sont :

- Pour les éléments immatériels de type « données » :
  - Les Fichiers ou bases de données
  - Les données en transit
  - Le courriel en transit
- Pour les éléments matériels support de données
  - Les médias support de données
  - Les documents
  - Le courrier en transit
  - Les médias support d'archive
- Pour les éléments immatériels de type « service »
  - Les configurations systèmes et applications
- Pour les éléments matériels support de services
  - Les équipements de l'infrastructure informatique
  - L'environnement de travail et les équipements des utilisateurs
  - Les médias support de logiciels
- Pour les éléments mixtes de type « service »
  - L'infrastructure matérielle et logicielle support de services externalisés
- Pour les éléments immatériels de type « processus »
  - Les procédures support des processus

16. Annexe : Exposition naturelle standard

Evénements déclencheurs : types et Exposition naturelle standard

Type	*Code*	*Événement*	*Exposition naturelle standard CLUSIF*
Absence de personnel	AB.P.Per	Absence accidentelle de personnel interne ou de partenaire	3
Absence ou indisponibilité accidentelle de service	AB.S.Gen	Absence de services généraux : défaillance ou indisponibilité de services généraux ou de servitudes, énergie, climatisation, etc.	2
	AB.S.Loc	Absence de service : Impossibilité d'accès aux locaux	2
	AB.S.Mat	Absence de matériel compatible ou incompatibilité de systèmes	2
	AB.S.Ser	Absence de service : défaillance ou indisponibilité des services fournis par un prestataire externe	3
Accident grave d'environnement	AC.E.Evt	Accident grave d'environnement : Incendie, Inondation, foudroiement, tremblement de terre… ou dû à du terrorisme	2
Accident matériel	AC.M.Equ	Panne ou dysfonctionnement d'équipement	3
Action humaine (délibérée ou non) menée par voie logique ou fonctionnelle	AH.L.Blo	Attaque en blocage de comptes	2
	AH.L.Cap	Captation de données ou messages en transit	2
	AH.L.Cav	Captation visuelle de données	3
	AH.L.Cfg	Effacement volontaire ou pollution massive de configurations systèmes	2
	AH.L.Del	Effacement délibéré de supports logiques ou physiques	3
	AH.L.Fal	Falsification logique (données ou fonctions)	3
	AH.L.Fau	Création de faux (messages ou données)	3
	AH.L.Kyl	Captation de données par Keylogger logiciel	3
	AH.L.Phi	Action menée par abus de confiance (Phishing)	3
	AH.L.Sam	Saturation malveillante d'équipements informatiques ou réseaux	3
	AH.L.Tot	Destruction logique totale (fichiers et leurs sauvegardes)	2
	AH.L.Vol	Détournement logique de fichiers ou données (téléchargement ou copie)	3
Action humaine menée par voie physique	AH.P.Fal	Manipulation ou falsification matérielle d'équipement ou de media	2
	AH.P.Kyp	Captation de données par Keylogger physique	3
	AH.P.Phc	Duplication, photocopie ou consultation de media physique	3
	AH.P.Vol	Vol ou substitution physique	3
Erreur matérielle ou de comportement du personnel	ER.P.Peo	Perte ou oubli de document ou de media	3
	ER.P.Pro	Erreur de manipulation ou dans le suivi d'une procédure	3
	ER.P.Prs	Erreur de saisie ou de frappe	3
Incident dû à l'environnement	IC.E.Div	Dégâts divers dus à l'environnement (vieillissement, pollution, dégâts des eaux, surcharge électrique, etc.) ou à du vandalisme	2
Incident logique ou fonctionnel	IF.L.Lsp	Bug bloquant dans un logiciel système, middleware, applicatif ou un progiciel	2
	IF.L.Vir	Logiciel malveillant ou virus	4
Procédures adéquates non appliquées	PR.N.Nai	Procédures adéquates absentes ou méconnues	2
	PR.N.Nar	Conflit non ou mal résolu entre procédures	2
	PR.N.Nav	Procédures inappliquées volontairement	2

© Clusif 2022



L'ESPRIT D'ECHANGE

Tour Eria
5 rue Bellini
92821 Puteaux cedex
✆ 01 53 25 08 80
clusif@clusif.fr

https://clusif.fr